

Fraud exposure, target control environment and implementation programme

43.33

READINESS / 100

DEVELOPING

MATURITY BAND

PREPARED FOR

Vhutshilo Foods Manufacturing (Pty) Ltd

Assessment reference · MKFRS-V12-COMP-VHUTSHILO

CONFIDENTIAL · AUTOMATED ANALYSIS · NOT INDEPENDENTLY REVIEWED

Contents

Management report	SECTIONS 1–9
1 · Where the organisation stands	
2 · What is driving the position	
3 · Where the material fraud exposure sits	
4 · Fraud scenario portfolio	
5 · The control environment management should build	
6 · Who must own the response	
7 · Decisions leadership must make	
8 · What should happen, and in what order	
9 · How management will know it is working	
 Analytical registers	 APPENDICES A–F
A · Finding register	25 entries
B · Fraud risk register	24 entries
C · Control blueprint register	25 entries
D · Evidence requirement register	105 entries
E · 12-month action and assurance register	69 entries
F · Measurement register	25 entries

THE TWO HALVES OF THIS REPORT

Sections 1–9 are the management report: what the assessment shows, what it means, and what to do about it. Appendices A–F are the analytical registers behind those sections — every finding, risk, control design, evidence requirement, action and measure, with the identifiers that connect them. The management sections state nothing the registers do not hold.

BASIS OF THIS REPORT

This report is produced by automated analysis of the recorded MK Fraud Readiness assessment. It has not been independently reviewed. No evidence has been examined, no control has been tested for operating effectiveness, no personnel have been interviewed, and no assurance opinion is given. Assessment positions are self-reported by the organisation. Recommended control designs, evidence requirements and operating measures are MK methodology — what good practice requires — not observations of what the organisation currently does.

The assessed readiness position

43.33	Developing	10	25	25
READINESS SCORE OUT OF 100	MATURITY BAND	DOMAINS ASSESSED	MATERIAL FINDINGS	CONTROL DESIGNS RECOMMENDED

Domain readiness profile

Fraud Leadership and Governance		42.00	Developing
Fraud Risk Identification		39.43	Reactive
Operational Fraud Controls		40.54	Developing
Fraud Detection Capability		40.59	Developing
Fraud Incident Response		43.85	Developing
Whistleblowing and Reporting Culture		60.83	Structured
Third-Party and Supply Chain Fraud Risk		47.06	Developing
Digital and Identity Fraud Risk		38.18	Reactive
Fraud Culture and Awareness		56.67	Developing
Continuous Improvement and Fraud Risk Monitoring		40.95	Developing

Ordered as assessed. Positions are self-reported through the assessment and have not been independently verified.

EXECUTIVE INTERPRETATION

Vhutshilo Foods Manufacturing (Pty) Ltd has an overall score of 43.33 and a Developing maturity position. The domain profile is uneven: Whistleblowing and Reporting Culture is Structured at 60.83, while Fraud Risk Identification is Reactive at 39.43 and Digital and Identity Fraud Risk is Reactive at 38.18. The other domains are mainly Developing, including Fraud Leadership and Governance at 42, Operational Fraud Controls at 40.54, Fraud Detection Capability at 40.59 and Fraud Incident Response at 43.85. The central issue is the relationship between awareness and execution. The organisation reports a comparatively stronger willingness or structure for reporting, but weaker ability to identify exposure, challenge authority, detect unusual activity and respond with reliable evidence. That gap means reported readiness cannot yet be relied on. The assessment therefore calls for remediation of material weaknesses, with leadership attention focused first on the capabilities that prevent, detect and contain misuse of authority and value.

The patterns beneath the score

The assessment produced 25 material findings. They resolve into 8 connected patterns, ordered by how much of the organisation's critical control population each one affects.

PATTERN	FINDINGS	CRITICAL	HARD GATE	MANAGEMENT QUESTION THIS RAISES
Identity and access challenge Digital and Identity Fraud Risk · Operational Fraud Controls	5	2	2	Is authority verified at the points where it can be misused?
Detection and exception review Fraud Detection Capability	6	1	1	Would unusual activity be seen and challenged in time?
Incident response and evidence integrity Fraud Incident Response · Whistleblowing and Reporting Culture	5	1	1	When something is suspected, can we contain it and keep the evidence?
Supplier and payment integrity Operational Fraud Controls · Third-Party and Supply Chain Fraud Risk	4	1	1	Can value be redirected before anyone independently challenges it?
Fraud governance and risk identification Fraud Risk Identification · Operational Fraud Controls	2	1	1	Does anyone own fraud risk, and do we know where it sits?
Payroll integrity Operational Fraud Controls	1	—	—	Can payroll master-file and payment changes be independently challenged before release?
Cash custody and reconciliation Operational Fraud Controls	1	—	—	Are cash custody, counting and banking differences visible and owned?
Stock and physical-asset integrity Operational Fraud Controls	1	—	—	Are stock and physical-asset movements reconciled and challenged?

Every finding behind these patterns is listed in Appendix A.

WHY THIS MATTERS

The main operational exposure is Detection and exception review, with 6 risks: unusual activity may not be seen and challenged in time. That creates a pathway for normal transactions or system activity to continue without timely scrutiny. Incident response and evidence integrity follows with 5 risks. When suspicion arises, weak containment or poor evidence integrity can allow the situation to spread or make the facts harder to establish, weakening trust in the response. Identity and access challenge and Supplier and payment integrity each contain 4 risks. If authority is not verified where it can be misused, or if value can be redirected before independent challenge, ordinary access, supplier and payment activity can become the route through which value leaves the organisation. These exposures reinforce one another: missed exceptions delay challenge, and weak identity or payment challenge gives the underlying activity room to proceed.

Exposure by control family

24 fraud risks arise from the assessed position. They concentrate in 8 exposure families.

EXPOSURE FAMILY	RISKS	DOMAINS AFFECTED	WHAT THE ORGANISATION IS EXPOSED TO
Detection and exception review	6	D4	Would unusual activity be seen and challenged in time?
Incident response and evidence integrity	5	D5 · D6	When something is suspected, can we contain it and keep the evidence?
Identity and access challenge	4	D8 · D3, D8	Is authority verified at the points where it can be misused?
Supplier and payment integrity	4	D3 · D7	Can value be redirected before anyone independently challenges it?
Fraud governance and risk identification	2	D2 · D3	Does anyone own fraud risk, and do we know where it sits?
Payroll integrity	1	D3	Can payroll master-file and payment changes be independently challenged before release?
Cash custody and reconciliation	1	D3	Are cash custody, counting and banking differences visible and owned?
Stock and physical-asset integrity	1	D3	Are stock and physical-asset movements reconciled and challenged?

Full risk statements, causes and treatment directions are in Appendix B. Risks are derived from assessed control positions; no likelihood or monetary value is assigned, because the assessment does not support one.

MANAGEMENT IMPLICATION

Management must make six specific choices. The Chief Executive / Managing Director must approve accountable executive mandates and escalation authority within 60 days, so priority remediation has authority to allocate resources and resolve blockers. The same owner must choose remediation rather than passive acceptance for Critical and High risks within 60 days, making treatment explicit where consequence pathways are plausible. Within 30 days, the Chief Executive / Managing Director must approve one target control standard across priority areas and approve prerequisite-first sequencing, so functions work to a common baseline and dependent improvements are not advanced prematurely. Finance must approve specialist capacity and resources for high-difficulty controls within 60 days. Finally, the Chief Executive / Managing Director must approve a fixed fraud-risk implementation and control-effectiveness review cadence within 60 days, turning the linked registers into a managed programme rather than a one-time exercise.

SECTION 4

Fraud scenario portfolio

Conditional pathways derived from the recorded control position. Each shows how it could begin, how it could progress, the control response that would interrupt it, and what management could observe first. No allegation that any event has occurred.

PATHWAY	HOW IT COULD BEGIN	HOW IT COULD PROGRESS	INTERRUPTION POINT	WARNING INDICATORS	LINKS
Supplier or payment instruction is diverted through a compromised or fictitious relationship SUPPLIER PAYMENT DIVERSION	A supplier or bank-detail amendment is submitted shortly before a scheduled payment.	An actor submits a credible-looking bank-detail change and diverts a genuine payment before the change is independently challenged.	Procurement performs a pre-activation checklist across every proposed supplier, independently verifies registration and bank ownership, screens beneficial owners and conflicts, risk-rates the supplier, and blocks ERP activation until a second reviewer signs.	- New or reactivated supplier before independent verification - Bank-detail change shortly before payment - Urgent payment request that bypasses the normal callback route	RISK-006
Privileged access is used to alter a value-bearing record, entitlement or audit trail PRIVILEGED ACCESS MISUSE	A privileged, administrative or emergency-access account remains usable without independent periodic review.	An actor uses privileged access to alter a record, entitlement or transaction and relies on weak recertification or monitoring to avoid timely challenge.	IT Security must maintain a complete sensitive-access inventory, require named identities and strong authentication, enforce least privilege and session logging, and remove access when the business justification ends.	- Emergency or administrator access outside the role pattern - Unusual record or entitlement change - Access review exception remains overdue	RISK-007
Records or reporting are weakened after a suspected fraud matter, allowing exposure to repeat INCIDENT CONCEALMENT	A suspected matter generates records before a retention, legal-hold or custody decision is made.	An actor delays, alters or fragments relevant records so that the scope, timing or responsibility for the suspected matter becomes harder to establish.	The investigation lead opens an evidence register for every material case.	- An exception, access, approval or incident record that cannot be reconciled to the complete in-scope population. - Any unexplained custody gap, integrity mismatch or unauthorised repository access. - Concern is reported through a channel controlled by the implicated process - Relevant records are unavailable or custody is unclear - Severity or containment decision remains overdue	RISK-003

The control programmes

The 25 recommended control designs group into 8 programmes. Each is one coherent piece of work with one accountable executive.

PROGRAMME	CONTROLS	EVIDENCE	MEASURES	ACCOUNTABLE	HORIZON
Detection and exception review	6	25	6	Finance operations accountable owner	60 days, 90 days, 30 days
Identity and access challenge	5	19	5	Operations accountable owner	60 days, 90 days
Incident response and evidence integrity	5	21	5	Legal	30 days, 60 days
Supplier and payment integrity	4	17	4	Finance and payment operations	60 days, 90 days
Fraud governance and risk identification	2	8	2	Finance and payment operations	90 days, 60 days
Payroll integrity	1	5	1	Finance operations accountable owner	60 days
Cash custody and reconciliation	1	5	1	Finance and payment operations	60 days
Stock and physical-asset integrity	1	5	1	Finance and payment operations	90 days

Individual control designs are in Appendix C; the evidence each requires is in Appendix D.

CONTROL PROGRAMME SYNTHESIS

The recommended programmes form a connected chain rather than separate workstreams. Detection and exception review is the largest programme, with 6 controls, 25 evidence items and 6 measures, owned by the Finance operations accountable owner. Identity and access challenge contributes 5 controls, 19 evidence items and 5 measures under the Operations accountable owner, establishing the authority challenge on which meaningful exception review depends. Supplier and payment integrity adds 4 controls, 17 evidence items and 4 measures under Finance and payment operations, applying that challenge where value can be redirected. Incident response and evidence integrity, owned by Legal, links 5 controls, 21 evidence items and 5 measures to containment and preservation when concerns arise. Governance and risk identification provides the direction for these programmes through 2 controls, 8 evidence items and 2 measures. Payroll integrity, cash custody and reconciliation, and stock and physical-asset integrity address focused value pathways. The programme owners must align standards, data, escalation and measures so one weakness does not undermine the others.

Programme detail

Detection and exception review6 CONTROLS

Would unusual activity be seen and challenged in time?

Accountable · Finance operations accountable owner
Evidence expected · 25 items across 6 controls
Controls: C-01, C-02, C-03, C-04, C-05, C-06

Delivery horizon · 60 days, 90 days, 30 days
Effectiveness measures · 6

Identity and access challenge5 CONTROLS

Is authority verified at the points where it can be misused?

Accountable · Operations accountable owner
Evidence expected · 19 items across 5 controls
Controls: C-07, C-08, C-09, C-10, C-11

Delivery horizon · 60 days, 90 days
Effectiveness measures · 5

Incident response and evidence integrity5 CONTROLS

When something is suspected, can we contain it and keep the evidence?

Accountable · Legal
Evidence expected · 21 items across 5 controls
Controls: C-12, C-13, C-14, C-15, C-16

Delivery horizon · 30 days, 60 days
Effectiveness measures · 5

Programme detail

Supplier and payment integrity4 CONTROLS

Can value be redirected before anyone independently challenges it?

Accountable · Finance and payment operations
Evidence expected · 17 items across 4 controls
Controls: C-17, C-18, C-19, C-20

Delivery horizon · 60 days, 90 days
Effectiveness measures · 4

Fraud governance and risk identification2 CONTROLS

Does anyone own fraud risk, and do we know where it sits?

Accountable · Finance and payment operations
Evidence expected · 8 items across 2 controls
Controls: C-21, C-22

Delivery horizon · 90 days, 60 days
Effectiveness measures · 2

Payroll integrity1 CONTROLS

Can payroll master-file and payment changes be independently challenged before release?

Accountable · Finance operations accountable owner
Evidence expected · 5 items across 1 controls
Controls: C-23

Delivery horizon · 60 days
Effectiveness measures · 1

Programme detail

Cash custody and reconciliation1 CONTROLS

Are cash custody, counting and banking differences visible and owned?

Accountable · Finance and payment operations
Evidence expected · 5 items across 1 controls

Controls: C-24

Delivery horizon · 60 days
Effectiveness measures · 1

Stock and physical-asset integrity1 CONTROLS

Are stock and physical-asset movements reconciled and challenged?

Accountable · Finance and payment operations
Evidence expected · 5 items across 1 controls

Controls: C-25

Delivery horizon · 90 days
Effectiveness measures · 1

The governance model

Accountability is expressed as roles, not individuals. The assessment does not identify people, and this report does not infer them.

ROLE	STANDING	CONTROLS	DECISIONS	EVIDENCE	ESCALATION RESPONSIBILITY
Finance operations accountable owner	executive accountability	5	—	—	—
Operations accountable owner	executive accountability	5	—	—	—
Technology security accountable owner	executive accountability	2	—	—	—
People workforce accountable owner	executive accountability	1	—	—	—
Chief Executive / Managing Director	executive accountability	—	5	—	—
Finance	executive accountability	—	1	—	—
Finance and payment operations	process ownership	8	—	4	A sensitive payroll change released without review, unexplained duplicate or ghost record, or unresolved exception at payment release.
Risk function	process ownership	6	—	25	Any supplier activated before verification or any ownership/conflict match unresolved.
Technology and information security	process ownership	4	—	15	Any unknown or unjustified privileged account, missed recertification or leaver access beyond 24 hours.
Procurement and vendor management	process ownership	3	—	13	—
People, learning and ethics	process ownership	3	—	12	—
Investigation and incident response	process ownership	3	—	13	—
Payroll	process ownership	1	—	5	—
Site operations	process ownership	1	—	5	—
Operations, Stores	process ownership	1	—	5	—
Independent governing oversight	oversight	2	—	—	A qualifying matter escalated late, or an escalation routed only through an implicated manager.
Legal	oversight	2	—	—	A case decision taken by an implicated party, or a stage with no recorded decision-maker.
Internal Audit	oversight	1	—	4	Any above-threshold release without independent approval, or a repeated splitting pattern by the same initiator.
Compliance	oversight	1	—	4	—
Risk Committee	oversight	—	—	—	Any material process unmapped, or a mapped residual gap with no owner.

The decision agenda

DECISION	WHY NOW	RECOMMENDED DIRECTION	OWNER	CONSEQUENCE OF DELAY
Approve accountable executive mandates and escalation authority for priority remediation.	Hard-gate, governance and maturity-limiting controls require authority to allocate resources and resolve blockers.	Name one accountable executive per linked control and approve a 30-day escalation route.	Chief Executive / Managing Director 60 days	Priority controls remain ownerless or blocked and the maturity reading remains constrained.
Choose and record remediation rather than passive acceptance for Critical and High risks.	Plausible consequence pathways require an explicit leadership treatment decision.	Approve linked treatments; any temporary acceptance must name an owner, expiry and compensating control.	Chief Executive / Managing Director 60 days	Known risk pathways remain untreated without a documented acceptance basis.
Approve the target control standards management will implement across the priority risk areas.	Functions need one design baseline rather than independent interpretations of the findings.	Adopt the control-improvement register; deviations require documented oversight approval.	Chief Executive / Managing Director 30 days	Partial or inconsistent designs fail to address the causal pathway.
Approve specialist capacity and resources for high-difficulty controls.	High-difficulty controls cannot meet target periods without committed capacity.	Fund the named supporting functions and require a resource-confirmed delivery plan.	Finance 60 days	The highest-complexity gaps remain open despite nominal approval.
Approve prerequisite-first sequencing for dependent improvements.	Dependent controls cannot operate reliably before prerequisite ownership, data or processes exist.	Approve the prerequisite sequence and escalate threatened prerequisites.	Chief Executive / Managing Director 30 days	Downstream controls are implemented on incomplete foundations.
Approve a fixed fraud-risk implementation and control-effectiveness review cadence.	The linked registers require continuing governance to become a managed programme.	Require monthly implementation reporting and quarterly control-effectiveness review through the organisation's management and oversight route.	Chief Executive / Managing Director 60 days	Actions lose momentum, exceptions remain open and management receives the control position too late to intervene.

A recommended direction is MK methodology. The decision remains management's.

The 12-month implementation programme

25 implementation actions, followed by 22 embed-and-evidence checkpoints, and 22 assure-and-review checkpoints across the 12-month programme. 69 programme objects in total, each with an owner, a deliverable and a test that shows it is complete.

HORIZON	WORK TYPE	COUNT	PROGRAMMES ADVANCED IN THIS HORIZON
30 days	Implement	2	Detection and exception review · Incident response and evidence integrity
60 days	Implement	14	Supplier and payment integrity · Incident response and evidence integrity · Identity and access challenge · Fraud governance and risk identification · Detection and exception review · Payroll integrity · Cash custody and reconciliation
90 days	Implement	9	Fraud governance and risk identification · Detection and exception review · Identity and access challenge · Supplier and payment integrity · Stock and physical-asset integrity
3-6 months	Embed & evidence	22	Fraud governance and risk identification · Supplier and payment integrity · Identity and access challenge · Payroll integrity · Cash custody and reconciliation · Stock and physical-asset integrity · Detection and exception review · Incident response and evidence integrity
6-12 months	Assure & review	22	Fraud governance and risk identification · Supplier and payment integrity · Identity and access challenge · Payroll integrity · Cash custody and reconciliation · Stock and physical-asset integrity · Detection and exception review · Incident response and evidence integrity

Every programme item, with its dependency and completion criterion, is in Appendix E.

IMPLEMENTATION SYNTHESIS

The sequence is designed to establish decision rights and operating foundations before relying on more complex improvements. The first horizon prioritises detection and incident evidence because unusual activity must be visible and suspected matters must be contained without compromising evidence. The next horizon converts those foundations into accountable delivery: leadership mandates, treatment decisions for Critical and High risks, specialist capacity, and ownership must be in place before controls can be implemented consistently. The following horizon reinforces the model by addressing dependent areas only after prerequisite ownership, data and processes are addressed. The longer horizons are for embedding the target standards across the organisation, sustaining operation across linked programmes, and introducing a fixed fraud-risk implementation and control-effectiveness review cadence. This prevents later improvements from being treated as reliable while the governance and process conditions they depend on remain unresolved.

The measurement framework

Each programme carries effectiveness measures drawn from the control designs behind it. These are the signals management should expect to see, not a claim that they exist today.

PROGRAMME	MEASURES	CONTROLS	ACCOUNTABLE FOR REPORTING
Detection and exception review	6	6	Finance operations accountable owner
Identity and access challenge	5	5	Operations accountable owner
Incident response and evidence integrity	5	5	Legal
Supplier and payment integrity	4	4	Finance and payment operations
Fraud governance and risk identification	2	2	Finance and payment operations
Payroll integrity	1	1	Finance operations accountable owner
Cash custody and reconciliation	1	1	Finance and payment operations
Stock and physical-asset integrity	1	1	Finance and payment operations

The individual measures are in Appendix F.

CONCLUSION

Successful progression would mean moving from a reported Developing position to a managed fraud-risk programme in which priority weaknesses are treated, accountable owners can escalate blockers, and the priority programmes operate to one approved standard. Management would know progress is real through the agreed measures, evidence requirements and fixed control-effectiveness review cadence, not through assumptions about implementation. The practical test is whether authority, unusual activity, redirected value and suspected incidents are consistently brought into view and handled through accountable processes. Progress should also narrow the gap between the stronger reporting culture and the weaker identification, digital access, detection and response capabilities identified in the assessment.

Finding register

Every material finding the assessment produced. "Assessment indication" is what the responses record; it is self-reported and has not been verified.

ID	DOMAIN	ASSESSMENT INDICATION	MATERIALITY	FRAUD MECHANISM	RISK	CONTROL
F-01 A-01	Fraud Risk Identification	Informal / reactive This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.	maturity constraint GATE	Organisation-level risk statements hide process-level opportunity, so a specific diversion route such as refund abuse or stock write-off manipulation is never mapped to a control owner.	RISK-CONTROL-A-01	C-21
F-02 A-02	Operational Fraud Controls	Partly designed This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.	maturity constraint GATE	A fictitious or conflicted supplier can be approved and used to route manipulated purchases or payments.	RISK-SUPPLIER-ONBOARDING	C-17
F-03 A-03	Digital and Identity Fraud Risk	Informal / reactive This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.	control failure GATE	Excess or unmanaged sensitive access allows records, controls or confidential data to be altered or concealed.	RISK-UNAUTHORISED-ACCESS	C-10
F-04 A-04	Fraud Incident Response	Informal / reactive This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.	control failure GATE	Uncontrolled collection or transfer can alter, lose or contaminate evidence, undermining investigation, recovery or disciplinary action.	RISK-EVIDENCE-INTEGRITY	C-13
F-05 A-05	Operational Fraud Controls	Partly designed This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.	control failure GATE	Access granted without a current role basis can enable a person to initiate, approve or alter activity beyond legitimate responsibility.	RISK-UNAUTHORISED-ACCESS	C-07
F-06 A-06	Fraud Detection Capability	Partly designed This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.	control failure GATE	As transaction volume grows, manual review may leave parts of the population without systematic scrutiny; risk-based data checks help surface suspicious patterns for investigation.	RISK-CONTROL-A-06	C-02
F-07 A-07	Operational Fraud Controls	Informal / reactive This recorded response and its surrounding exposure make the control materially relevant.	cross domain dependency	Absent or unenforced thresholds allow high-value diversion to pass on a single signature, and known thresholds invite deliberate splitting of transactions to stay below them.	RISK-CONTROL-A-07	C-22
F-08 A-08	Operational Fraud Controls	Informal / reactive This recorded response and its surrounding exposure make the control materially relevant.	cross domain dependency	Long-tenured sole operators in sensitive roles can build and maintain a concealment routine that only breaks when someone else performs the work.	RISK-CONTROL-A-08	C-08
F-09 A-09	Fraud Detection Capability	Informal / reactive This recorded response and its surrounding exposure make the control materially relevant.	cross domain dependency	Unreviewed exceptions allow suspicious transactions or control overrides to continue without challenge.	RISK-DETECTION-REVIEW	C-01

ID	DOMAIN	ASSESSMENT INDICATION	MATERIALITY	FRAUD MECHANISM	RISK	CONTROL
F-10 A-10	Fraud Detection Capability	Informal / reactive This recorded response and its surrounding exposure make the control materially relevant.	cross domain dependency	An insider can misuse an apparently legitimate role when internal activity and control overrides are not monitored and challenged.	RISK-CONTROL-A-10	C-03
F-11 A-11	Fraud Detection Capability	Informal / reactive This recorded response and its surrounding exposure make the control materially relevant.	cross domain dependency	External fraud can enter through customer, supplier, partner or outsourced channels when provider reporting is not connected to the organisation's own monitoring and response process.	RISK-EXTERNAL-FRAUD-MONITORING	C-06
F-12 A-12	Third-Party and Supply Chain Fraud Risk	Informal / reactive This recorded response and its surrounding exposure make the control materially relevant.	cross domain dependency	An undisclosed interest in a supplier lets an employee direct work, approve inflated invoices or tolerate non-delivery while appearing to act at arm's length.	RISK-CONTROL-A-12	C-18
F-13 A-13	Third-Party and Supply Chain Fraud Risk	Informal / reactive This recorded response and its surrounding exposure make the control materially relevant.	cross domain dependency	Intermediaries act with the organisation's authority but outside its control environment, so misuse of delegated authority, ghost transactions or diverted collections may never appear in internal records.	RISK-CONTROL-A-13	C-20
F-14 A-14	Digital and Identity Fraud Risk	Informal / reactive This recorded response and its surrounding exposure make the control materially relevant.	cross domain dependency	Access that was once justified can remain available after role change or operational change and enable unauthorised alteration or concealment.	RISK-PRIVILEGED-ACCESS-REVIEW	C-11
F-15 A-15	Operational Fraud Controls	Partly designed This recorded response and its surrounding exposure make the control materially relevant.	cross domain dependency	Stale access after role change or exit can be used to initiate, change or conceal activity outside current responsibilities.	RISK-ACCESS-REVIEW	C-09
F-16 A-16	Operational Fraud Controls	Partly designed This recorded response and its surrounding exposure make the control materially relevant.	cross domain dependency	An unauthorised bank, pay-rate or employee-record change, duplicate or ghost employee can divert payroll value before the payment run is released.	RISK-PAYROLL-MASTER-FILE	C-23
F-17 A-17	Operational Fraud Controls	Partly designed This recorded response and its surrounding exposure make the control materially relevant.	cross domain dependency	Weak custody and delayed reconciliation can allow cash shortages, diversion or concealment within ordinary operational variance.	RISK-CASH-CUSTODY	C-24
F-18 A-18	Operational Fraud Controls	Partly designed This recorded response and its surrounding exposure make the control materially relevant.	cross domain dependency	Uncontrolled movement, inaccurate counts or unsupported write-offs can conceal theft, diversion or unauthorised disposal of physical value.	RISK-STOCK-ASSET-CUSTODY	C-25
F-19 A-19	Fraud Detection Capability	Partly designed This recorded response and its surrounding exposure make the control materially relevant.	cross domain dependency	Analysts who lack clear authority or fear contradicting a senior colleague delay or suppress escalation, allowing a detected scheme to continue.	RISK-CONTROL-A-19	C-04
F-20 A-20	Fraud Detection Capability	Partly designed This recorded response and its surrounding exposure make the control materially relevant.	cross domain dependency	Detection that runs but produces unreviewed or wrongly closed output gives false assurance, and the team operating it is not positioned to identify its own blind spots.	RISK-CONTROL-A-20	C-05

ID	DOMAIN	ASSESSMENT INDICATION	MATERIALITY	FRAUD MECHANISM	RISK	CONTROL
F-21 A-21	Fraud Incident Response	Partly designed This recorded response and its surrounding exposure make the control materially relevant.	cross domain dependency	Undefined decision rights cause delay, duplicated or contradictory action, and allow an implicated manager to influence the handling of their own case.	RISK-CONTROL-A-21	C-12
F-22 A-22	Fraud Incident Response	Partly designed This recorded response and its surrounding exposure make the control materially relevant.	cross domain dependency	Internal teams attempting complex digital or financial forensics without capability can destroy evidence and foreclose recovery or prosecution.	RISK-CONTROL-A-22	C-14
F-23 A-23	Whistleblowing and Reporting Culture	Partly designed This recorded response and its surrounding exposure make the control materially relevant.	cross domain dependency	A channel that people cannot find, do not trust or do not understand produces no reports, leaving management to believe silence means absence of fraud.	RISK-CONTROL-A-23	C-15
F-24 A-24	Whistleblowing and Reporting Culture	Partly designed This recorded response and its surrounding exposure make the control materially relevant.	cross domain dependency	External warnings can be lost when suppliers, customers or other affected parties have no safe route to report suspected misconduct.	RISK-CONTROL-A-24	C-16
F-25 A-25	Third-Party and Supply Chain Fraud Risk	Partly designed This recorded response and its surrounding exposure make the control materially relevant.	cross domain dependency	A supplier verified once can change ownership, subcontract to an undisclosed party or drift into inflated pricing, and nothing re-tests the original assurance.	RISK-CONTROL-A-25	C-19

Fraud risk register

Risks implied by the assessed control positions. No likelihood, monetary value or incident frequency is assigned, because the assessment does not support one.

ID	RISK	CURRENT CONTROL POSITION	REQUIRED TREATMENT	OWNER ROLE
RISK-CONTROL-A-01 F-01	Because the self-assessment records "Fraud risks are mapped to the organisation's important processes" as "Informal / reactive"; the expected control standard is therefore not yet met, there is a risk that organisation-level risk statements hide process-level opportunity, so a specific diversion route such as refund abuse or stock write-off manipulation is never mapped to a control owner. Consequence pathway: Material process exposures can remain without explicit control ownership or treatment; Unmapped process-level fraud routes can leave value diversion or loss outside targeted controls.	Fraud Risk Identification: Informal / reactive — Some activity occurs, but it is informal, reactive or dependent on individual effort	The Risk compliance accountable owner must produce a process-by-process fraud map covering every material value-bearing process: for each, record the fraud scenarios, the roles and system permissions able to execute them alone or in collusion, the preventive and detective controls relied upon, and the residual gap; process owners sign their own map, and any process without a mapped control owner escalates to the fraud-risk executive.	Finance and operations accountable owner
RISK-CONTROL-A-06 F-06	Because the self-assessment records "Analytics, rules, reports or data checks are used to identify suspicious transactions, behaviour or control exceptions" as "Partly designed"; the expected control standard is therefore not yet met, there is a risk that as transaction volume grows, manual review may leave parts of the population without systematic scrutiny; risk-based data checks help surface suspicious patterns for investigation. Consequence pathway: Alert backlogs can conceal important anomalies; unreviewed exceptions can allow losses to compound.	Fraud Detection Capability: Partly designed — The capability has been partly designed, but important elements are incomplete or inconsistent	The monitoring owner must maintain a rule catalogue in which every test names the fraud scenario it addresses, the data source, the threshold and the reviewing role; tests include duplicate and near-duplicate payments, supplier and employee bank-detail or address matches, unusual approval pairings, dormant-account reactivation and threshold-adjacent transaction clustering; results reconcile to source control totals and rules are tuned monthly from confirmed true and false positives.	Finance operations accountable owner / Technology security accountable owner
RISK-EVIDENCE-INTEGRITY F-04	Because evidence identification, preservation, integrity checks and custody transfers are not consistently controlled, there is a risk that material evidence is altered, lost, contaminated or cannot be shown to be authentic. Consequence pathway: evidence, retention or legal-hold duties may be breached; investigations must be repeated or abandoned; recovery, disciplinary or legal outcomes are weakened; the organisation cannot substantiate its response.	Fraud Incident Response: Informal / reactive — Some activity occurs, but it is informal, reactive or dependent on individual effort	The investigation lead opens an evidence register for every material case; trained custodians identify sources, create forensic copies or sealed originals, record hashes/seal numbers, collector/time/location and every transfer, store evidence in access-controlled repositories, and escalate any custody break immediately to Legal.	Legal investigations accountable owner / Operations accountable owner
RISK-PAYROLL-MASTER-FILE F-16	Because payroll master-file changes, joiner/mover/leaver reconciliation and unusual-record review are not independently completed before payment, there is a risk that an unauthorised change, duplicate or ghost payroll record diverts value through a payment run. Consequence pathway: employees and stakeholders lose confidence in payroll integrity; payroll correction and employee trust are disrupted; payroll, tax or employment obligations may be affected; salary or benefit value is paid to an unauthorised destination.	Operational Fraud Controls: Partly designed — The capability has been partly designed, but important elements are incomplete or inconsistent	Payroll and Human Resources must reconcile joiner, mover and leaver records to the payroll master file before each payment run, independently review bank-account and pay-rate changes, test for duplicate or ghost records and unusual payments, and retain reviewer decisions and exception closure before release.	Finance operations accountable owner / People workforce accountable owner

ID	RISK	CURRENT CONTROL POSITION	REQUIRED TREATMENT	OWNER ROLE
RISK-PRIVILEGED-ACCESS-REVIEW F-14	Because sensitive-access and administrator populations are not periodically recertified against current ownership and business need, there is a risk that stale or excessive rights are used to alter value-bearing records, entitlements or confidential data. Consequence pathway: access, security or confidentiality obligations may be breached; stakeholders lose confidence in sensitive-system governance; system integrity and investigation confidence are weakened; unauthorised changes or transactions create direct loss.	Digital and Identity Fraud Risk: Informal / reactive — Some activity occurs, but it is informal, reactive or dependent on individual effort	IT Security must reconcile the complete sensitive-access and administrator population to current owners and role requirements at least quarterly, obtain an independent keep/remove decision from system owners, record exceptions and close removals within the defined service level; emergency and service accounts are included.	Technology security accountable owner
RISK-SUPPLIER-ONBOARDING F-02	Because supplier identity, ownership, banking and conflict checks are incomplete or not evidenced before activation, there is a risk that a fictitious, conflicted or misrepresented supplier is approved and used for purchasing or payment. Consequence pathway: funds are paid to an illegitimate or related party; procurement and vendor-master integrity are compromised; sanctions, conflict or procurement obligations may be breached; stakeholders lose confidence in supplier governance.	Operational Fraud Controls: Partly designed — The capability has been partly designed, but important elements are incomplete or inconsistent	Procurement performs a pre-activation checklist across every proposed supplier, independently verifies registration and bank ownership, screens beneficial owners and conflicts, risk-rates the supplier, and blocks ERP activation until a second reviewer signs; the vendor master retains the evidence package.	Finance and operations accountable owner
RISK-UNAUTHORISED-ACCESS F-05, F-03	Because privileged, administrator or sensitive-data access is not completely restricted, logged and independently recertified, there is a risk that a privileged user or compromised administrator identity alters records, controls or logs without timely detection. Consequence pathway: confidence in digital controls is damaged; critical systems and audit trails lose integrity; high-impact transactions or data can be manipulated; security and personal-data obligations may be breached.	Digital and Identity Fraud Risk: Informal / reactive — Some activity occurs, but it is informal, reactive or dependent on individual effort; Operational Fraud Controls: Partly designed — The capability has been partly designed, but important elements are incomplete or inconsistent	IT Security must maintain a complete sensitive-access inventory, require named identities and strong authentication, enforce least privilege and session logging, and remove access when the business justification ends; periodic recertification is handled by the separate access-review control. System owners must maintain a current role-to-access matrix, require business-owner approval against the requester's current duties before granting access, separate incompatible initiation and approval rights, and retain the request, approval and provisioning trail.	Technology security accountable owner
RISK-ACCESS-REVIEW F-15	Because the complete ordinary-user access population is not periodically reconciled to current responsibilities and removal decisions, there is a risk that a former or transferred user retains access that can initiate, change or conceal activity. Consequence pathway: access exceptions and removal work accumulate without accountable closure; stakeholders may lose confidence in the organisation's access discipline; unauthorised changes or transactions can create direct loss.	Operational Fraud Controls: Partly designed — The capability has been partly designed, but important elements are incomplete or inconsistent	System owners must export the complete active-user access population on a defined cycle, obtain business-owner keep/remove decisions against current responsibilities, route exceptions to IT for closure and reconcile leaver and mover removals to the HR feed.	Operations accountable owner
RISK-CASH-CUSTODY F-17	Because cash custody, counting, banking and reconciliation are not consistently assigned, independently checked and investigated, there is a risk that cash shortages or diversion remain within ordinary variance without timely challenge. Consequence pathway: cash-handling or recordkeeping obligations may be affected; management cannot demonstrate custody over cash entrusted to the organisation; physical cash is lost or unrecovered; site cash operations and banking continuity are disrupted.	Operational Fraud Controls: Partly designed — The capability has been partly designed, but important elements are incomplete or inconsistent	Finance and site managers must assign cash custodians, perform opening and closing counts with independent review, reconcile takings to receipts and bankings, record sealed transfers and investigate every shortage or overage against a defined threshold before the next cycle closes.	Finance and operations accountable owner

ID	RISK	CURRENT CONTROL POSITION	REQUIRED TREATMENT	OWNER ROLE
RISK-DETECTION-REVIEW F-09	Because the complete population of alerts and exception reports is not evidenced as assigned, investigated and independently reviewed, there is a risk that material anomalous activity is missed, closed without support or allowed to remain overdue. Consequence pathway: losses compound while suspicious activity continues; monitoring backlogs and unsupported closures weaken detection.	Fraud Detection Capability: Informal / reactive — Some activity occurs, but it is informal, reactive or dependent on individual effort	The monitoring owner generates a complete daily or weekly exception queue, assigns each alert to a trained reviewer, records investigation evidence and disposition, and escalates high-risk alerts immediately and all overdue alerts weekly; Risk performs a monthly closure-quality sample.	Finance and operations accountable owner
RISK-EXTERNAL-FRAUD-MONITORING F-11	Because external-party fraud threats and provider-operated channel reporting are not completely covered, reconciled and assigned for review, there is a risk that customer, supplier, partner or provider-channel fraud continues without timely organisational response. Consequence pathway: customer, supplier or data-protection obligations may be affected; external fraud causes loss before the organisation can intervene; external stakeholders lose confidence in the organisation's channel oversight; provider or channel incidents require wider containment and correction.	Fraud Detection Capability: Informal / reactive — Some activity occurs, but it is informal, reactive or dependent on individual effort	The fraud-monitoring owner must identify relevant external-party threats across customer, supplier, partner and provider-operated channels, define required provider reports and data quality checks, reconcile those reports to the organisation's own systems where possible, and route exceptions into owned triage and escalation.	Operations accountable owner / Technology security accountable owner
RISK-STOCK-ASSET-CUSTODY F-18	Because custody, movement, count, reconciliation, write-off and disposal controls are not consistently applied across locations, there is a risk that stock or physical assets are diverted, lost or written off without timely challenge. Consequence pathway: asset records or disposal obligations may be misstated; inventory or asset value is lost or understated; service and supply continuity are disrupted by unexplained shortages; stakeholders lose confidence in physical-asset stewardship.	Operational Fraud Controls: Partly designed — The capability has been partly designed, but important elements are incomplete or inconsistent	Operations and Finance must maintain a complete stock and asset register, assign custodians, require authorised movement and disposal records, perform risk-based counts across locations, reconcile results to the ledger or inventory system and independently approve write-offs and investigate shrinkage exceptions.	Finance and operations accountable owner
RISK-CONTROL-A-07 F-07	Because the self-assessment records "Transactions or operational activities above defined risk or value thresholds require independent review or approval" as "Informal / reactive"; the expected control standard is therefore not yet met, there is a risk that absent or unenforced thresholds allow high-value diversion to pass on a single signature, and known thresholds invite deliberate splitting of transactions to stay below them. Consequence pathway: access or supplier-control weakness can enable unauthorised payments or manipulation; Preventive controls may not match current roles or approved suppliers.	Operational Fraud Controls: Informal / reactive — Some activity occurs, but it is informal, reactive or dependent on individual effort	The Finance operations accountable owner must approve a delegation of authority matrix setting value and risk thresholds by transaction type, configure the finance and operational systems to block release above threshold without a second independent approver, prohibit self-approval and approval by direct reports of the initiator, and run a monthly report for split transactions falling just below thresholds and for any threshold override.	Finance operations accountable owner
RISK-CONTROL-A-08 F-08	Because the self-assessment records "People in high-risk roles are subject to appropriate oversight, rotation, secondary review or other compensating controls" as "Informal / reactive"; the expected control standard is therefore not yet met, there is a risk that long-tenured sole operators in sensitive roles can build and maintain a concealment routine that only breaks when someone else performs the work. Consequence pathway: access or supplier-control weakness can enable unauthorised payments or manipulation; Preventive controls may not match current roles or approved suppliers.	Operational Fraud Controls: Informal / reactive — Some activity occurs, but it is informal, reactive or dependent on individual effort	Human Resources and the Risk compliance accountable owner must jointly define high-risk roles by authority, system access and asset custody, and apply documented measures to each: secondary review of sensitive outputs, periodic rotation or cross-training, a block-leave or cover period during which another person performs the duties, and enhanced transaction monitoring; measures are applied consistently, recorded, and reviewed annually for coverage and fairness.	Operations accountable owner / People workforce accountable owner

ID	RISK	CURRENT CONTROL POSITION	REQUIRED TREATMENT	OWNER ROLE
RISK-CONTROL-A-10 F-10	Because the self-assessment records "Monitoring covers fraud and control misuse by people inside the organisation" as "Informal / reactive"; the expected control standard is therefore not yet met, there is a risk that an insider can misuse an apparently legitimate role when internal activity and control overrides are not monitored and challenged. Consequence pathway: Alert backlogs can conceal important anomalies; unreviewed exceptions can allow losses to compound.	Fraud Detection Capability: Informal / reactive — Some activity occurs, but it is informal, reactive or dependent on individual effort	The monitoring owner must define internal-misuse scenarios for privileged use, overrides, unusual approvals, manual adjustments and other value-bearing activity; reconcile the monitored population to source systems, assign alerts to an independent reviewer and retain disposition and escalation evidence.	Finance operations accountable owner / Technology security accountable owner
RISK-CONTROL-A-19 F-19	Because the self-assessment records "People responsible for monitoring suspicious activity know when to escalate concerns and have authority to do so" as "Partly designed"; the expected control standard is therefore not yet met, there is a risk that analysts who lack clear authority or fear contradicting a senior colleague delay or suppress escalation, allowing a detected scheme to continue. Consequence pathway: Alert backlogs can conceal important anomalies; unreviewed exceptions can allow losses to compound.	Fraud Detection Capability: Partly designed — The capability has been partly designed, but important elements are incomplete or inconsistent	The Risk compliance accountable owner must publish escalation criteria defining what must be escalated, to whom and within what time, grant monitoring staff explicit authority to escalate directly to the fraud-risk executive or Independent governing oversight where a manager is implicated, protect escalators from retaliation, train the monitoring team annually, and review escalation timeliness against criteria each quarter.	Risk compliance accountable owner
RISK-CONTROL-A-20 F-20	Because the self-assessment records "Detection controls are periodically reviewed for effectiveness by management, risk, audit or another independent reviewer" as "Partly designed"; the expected control standard is therefore not yet met, there is a risk that detection that runs but produces unreviewed or wrongly closed output gives false assurance, and the team operating it is not positioned to identify its own blind spots. Consequence pathway: Alert backlogs can conceal important anomalies; unreviewed exceptions can allow losses to compound.	Fraud Detection Capability: Partly designed — The capability has been partly designed, but important elements are incomplete or inconsistent	The Independent governing oversight must commission a periodic independent evaluation of detection effectiveness covering coverage against the process fraud maps, data completeness, sample retesting of closed alerts for closure quality, and detection of deliberately seeded test conditions where practical; findings are reported to governance with owners and due dates, and remediation is tracked to closure.	Independent governing oversight
RISK-CONTROL-A-21 F-21	Because the self-assessment records "Roles and decision rights are defined for fraud triage, investigation, escalation and case closure" as "Partly designed"; the expected control standard is therefore not yet met, there is a risk that undefined decision rights cause delay, duplicated or contradictory action, and allow an implicated manager to influence the handling of their own case. Consequence pathway: Containment, investigation and legal action may be weakened; delayed response or compromised evidence increases investigation and recovery cost.	Fraud Incident Response: Partly designed — The capability has been partly designed, but important elements are incomplete or inconsistent	The incident-response lead must maintain a decision-rights matrix covering intake, severity, triage, investigation, escalation, disciplinary or recovery referral and closure; conflicts are recorded, independent challenge is available and every decision is retained in the case record.	Operations accountable owner / Legal investigations accountable owner
RISK-CONTROL-A-22 F-22	Because the self-assessment records "External specialists are considered when incidents require forensic, legal, cyber or investigative expertise" as "Partly designed"; the expected control standard is therefore not yet met, there is a risk that internal teams attempting complex digital or financial forensics without capability can destroy evidence and foreclose recovery or prosecution. Consequence pathway: Containment, investigation and legal action may be weakened; delayed response or compromised evidence increases investigation and recovery cost.	Fraud Incident Response: Partly designed — The capability has been partly designed, but important elements are incomplete or inconsistent	The incident-response lead must define engagement triggers such as suspected loss above a threshold, digital forensic imaging requirements, senior-management or governing-body involvement, cross-border elements or likely litigation; pre-qualify providers for forensic accounting, digital forensics and investigative legal support with confidentiality, privilege, data-protection and evidential-standard terms agreed in advance, and record the decision to engage or not engage in every qualifying case.	Legal investigations accountable owner / Finance operations accountable owner

ID	RISK	CURRENT CONTROL POSITION	REQUIRED TREATMENT	OWNER ROLE
RISK-CONTROL-A-23 F-23	Because the self-assessment records "Employees know how to recognise suspected fraud and use the reporting channel" as "Partly designed"; the expected control standard is therefore not yet met, there is a risk that a channel that people cannot find, do not trust or do not understand produces no reports, leaving management to believe silence means absence of fraud. Consequence pathway: Early-warning information may never reach an independent reviewer; suppressed reporting lets fraud continue longer.	Whistleblowing and Reporting Culture: Partly designed — The capability has been partly designed, but important elements are incomplete or inconsistent	The ethics owner must publish channel instructions covering how to access it by phone and web, what information helps, whether anonymity is available, what feedback the reporter can expect and the protection from retaliation, in the languages and formats used across operating locations; the channel is tested at least annually with a live submission confirming intake, acknowledgement and case creation, and awareness is measured with targeted follow-up where low.	People workforce accountable owner
RISK-CONTROL-A-24 F-24	Because the self-assessment records "Relevant external stakeholders have an appropriate way to report suspected fraud or misconduct" as "Partly designed"; the expected control standard is therefore not yet met, there is a risk that external warnings can be lost when suppliers, customers or other affected parties have no safe route to report suspected misconduct. Consequence pathway: Early-warning information may never reach an independent reviewer; suppressed reporting lets fraud continue longer.	Whistleblowing and Reporting Culture: Partly designed — The capability has been partly designed, but important elements are incomplete or inconsistent	The ethics owner must publish the external reporting route for each relevant stakeholder group, state confidentiality and anti-retaliation protections, restrict access to reports, route concerns away from implicated managers and monitor acknowledgement, triage and escalation times.	Independent governing oversight / CEO
RISK-CONTROL-A-12 F-12	Because the self-assessment records "Employees are required to disclose and manage conflicts of interest involving suppliers or third parties" as "Informal / reactive"; the expected control standard is therefore not yet met, there is a risk that an undisclosed interest in a supplier lets an employee direct work, approve inflated invoices or tolerate non-delivery while appearing to act at arm's length. Consequence pathway: false suppliers, invoices or bank changes can redirect payments; Vendor and payment integrity can be bypassed.	Third-Party and Supply Chain Fraud Risk: Informal / reactive — Some activity occurs, but it is informal, reactive or dependent on individual effort	The compliance owner must require annual and on-change declarations from every employee able to influence supplier selection, contracting, receipting or payment, covering directorships, shareholdings, family relationships and outside interests; declarations are tested against the vendor master for matching surnames, addresses, contact details and bank accounts, and every declared or detected conflict receives a documented management action such as recusal, reassignment or enhanced review, recorded in a conflict register.	Finance operations accountable owner / Legal investigations accountable owner
RISK-CONTROL-A-25 F-25	Because the self-assessment records "The organisation receives and reviews risk information about high-risk third parties managed on its behalf" as "Partly designed"; the expected control standard is therefore not yet met, there is a risk that a supplier verified once can change ownership, subcontract to an undisclosed party or drift into inflated pricing, and nothing re-tests the original assurance. Consequence pathway: false suppliers, invoices or bank changes can redirect payments; Vendor and payment integrity can be bypassed.	Third-Party and Supply Chain Fraud Risk: Partly designed — The capability has been partly designed, but important elements are incomplete or inconsistent	The vendor-risk owner must define a risk-based monitoring cycle in which high-risk third parties are re-screened for ownership and sanctions change, reviewed for delivery and quality performance, tested for pricing drift against benchmark or contract, and analysed for spend concentration and unusual growth; findings requiring action are logged with owners, and failure to complete a cycle triggers escalation to the Finance operations accountable owner.	Finance and operations accountable owner

ID	RISK	CURRENT CONTROL POSITION	REQUIRED TREATMENT	OWNER ROLE
RISK-CONTROL-A-13 F-13	Because the self-assessment records "Fraud risks are considered when using agents, brokers, distributors, intermediaries, partners or outsourced service providers where relevant" as "Informal / reactive"; the expected control standard is therefore not yet met, there is a risk that intermediaries act with the organisation's authority but outside its control environment, so misuse of delegated authority, ghost transactions or diverted collections may never appear in internal records. Consequence pathway: false suppliers, invoices or bank changes can redirect payments; Vendor and payment integrity can be bypassed.	Third-Party and Supply Chain Fraud Risk: Informal / reactive — Some activity occurs, but it is informal, reactive or dependent on individual effort	The relationship owner must ensure every intermediary or outsourced arrangement defines in contract the fraud-control obligations, the limits of delegated authority, the right to audit and obtain records, incident-notification duties and consequences for breach; oversight includes reconciliation of transactions and collections handled on the organisation's behalf, periodic assurance over the provider's relevant controls, and review of any sub-contracting before it occurs.	Finance and operations accountable owner

Control blueprint register

Recommended control standard for each finding. This is MK methodology — what good practice requires — not a description of what the organisation currently operates. The assessed state column records what the organisation reported for that control.

ASSESSED STATE KEY

- Informal / reactive — Some activity occurs, but it is informal, reactive or dependent on individual effort.; self-assessed and not independently verified.
- Partly designed — The capability has been partly designed, but important elements are incomplete or inconsistent.; self-assessed and not independently verified.

ID	OBJECTIVE	RECOMMENDED DESIGN	ASSESSED	OWNER / OVERSIGHT	FREQUENCY	EFFECTIVENESS TEST
C-21 A-01 90 days	Close the material control weakness recorded for "Fraud risks are mapped to the organisation's important processes".	The Risk compliance accountable owner must produce a process-by-process fraud map covering every material value-bearing process: for each, record the fraud scenarios, the roles and system permissions able to execute them alone or in collusion, the preventive and detective controls relied upon, and the residual gap; process owners sign their own map, and any process without a mapped control owner escalates to the fraud-risk executive.	STATE 1	Risk compliance accountable owner with named process owners Risk Committee / Internal Audit	Refreshed with the fraud risk assessment and on material process change	100% of material value-bearing processes have a signed fraud map with named controls and residual gaps.
C-22 A-07 60 days	Close the material control weakness recorded for "Transactions or operational activities above defined risk or value thresholds require independent review or approval".	The Finance operations accountable owner must approve a delegation of authority matrix setting value and risk thresholds by transaction type, configure the finance and operational systems to block release above threshold without a second independent approver, prohibit self-approval and approval by direct reports of the initiator, and run a monthly report for split transactions falling just below thresholds and for any threshold override.	STATE 1	Finance and operational process owners Internal Audit / Finance Control	Every qualifying transaction; monthly splitting and override review	100% of above-threshold transactions carry an independent second approval, with all overrides reviewed monthly.
C-17 A-02 60 days	Close the material control weakness recorded for "The organisation retains assurance over supplier identity, ownership and initial banking checks performed on its behalf".	Procurement performs a pre-activation checklist across every proposed supplier, independently verifies registration and bank ownership, screens beneficial owners and conflicts, risk-rates the supplier, and blocks ERP activation until a second reviewer signs; the vendor master retains the evidence package.	STATE 2	Procurement / Vendor Master Risk / Compliance	Before every supplier activation; annual refresh for high-risk suppliers	100% of newly activated suppliers have a complete, pre-activation evidence pack and independent approval.
C-07 A-05 60 days	Close the material control weakness recorded for "System and data access is granted against current role requirements".	System owners must maintain a current role-to-access matrix, require business-owner approval against the requester's current duties before granting access, separate incompatible initiation and approval rights, and retain the request, approval and provisioning trail.	STATE 2	Business system owners Risk / Internal Audit	Quarterly and on every joiner, mover or leaver event	100% population reviewed quarterly and 95% of removal exceptions closed within 10 business days.
C-08 A-08 90 days	Close the material control weakness recorded for "People in high-risk roles are subject to appropriate oversight, rotation, secondary review or other compensating controls".	Human Resources and the Risk compliance accountable owner must jointly define high-risk roles by authority, system access and asset custody, and apply documented measures to each: secondary review of sensitive outputs, periodic rotation or cross-training, a block-leave or cover period during which another person performs the duties, and enhanced transaction monitoring; measures are applied consistently, recorded, and reviewed annually for coverage and fairness.	STATE 1	Human Resources with process owners Risk / Internal Audit	Role list reviewed annually; measures applied continuously per role	Every identified high-risk role has at least one evidenced compensating measure operating in the period.

ID	OBJECTIVE	RECOMMENDED DESIGN	ASSESSED	OWNER / OVERSIGHT	FREQUENCY	EFFECTIVENESS TEST
C-09 A-15 60 days	Close the material control weakness recorded for "System and data access is reviewed periodically and removed when no longer required".	System owners must export the complete active-user access population on a defined cycle, obtain business-owner keep/remove decisions against current responsibilities, route exceptions to IT for closure and reconcile leaver and mover removals to the HR feed.	STATE 2	Business system owners Risk / Internal Audit	Quarterly and on every joiner, mover or leaver event	100% of ordinary system and data access is reviewed on schedule and stale access is removed within the defined service level.
C-23 A-16 60 days	Close the material control weakness recorded for "Payroll master-file changes and unusual payroll records receive review before payment".	Payroll and Human Resources must reconcile joiner, mover and leaver records to the payroll master file before each payment run, independently review bank-account and pay-rate changes, test for duplicate or ghost records and unusual payments, and retain reviewer decisions and exception closure before release.	STATE 2	Payroll and Human Resources Finance Control / Internal Audit	Before every payroll payment run; monthly trend review	Every payroll run has a completed independent pre-payment review with all exceptions resolved or formally escalated.
C-24 A-17 60 days	Close the material control weakness recorded for "Physical cash is counted, safeguarded and reconciled by defined people".	Finance and site managers must assign cash custodians, perform opening and closing counts with independent review, reconcile takings to receipts and bankings, record sealed transfers and investigate every shortage or overage against a defined threshold before the next cycle closes.	STATE 2	Site operations and Finance Finance Control / Internal Audit	Each cash-handling shift/day; monthly exception and trend review	All cash points reconcile each cycle, with every difference investigated and resolved or escalated within the defined period.
C-25 A-18 90 days	Close the material control weakness recorded for "Stock and physical assets are safeguarded and reconciled by defined people".	Operations and Finance must maintain a complete stock and asset register, assign custodians, require authorised movement and disposal records, perform risk-based counts across locations, reconcile results to the ledger or inventory system and independently approve write-offs and investigate shrinkage exceptions.	STATE 2	Operations, Stores and Asset Management Finance Control / Internal Audit	Movement on each event; periodic counts; monthly exception review	All material stock and physical assets are counted and reconciled on schedule, with shrinkage and write-offs independently reviewed.
C-01 A-09 60 days	Close the material control weakness recorded for "Exception reporting provides defined alerts for unusual transactions or activities and a documented review process".	The monitoring owner generates a complete daily or weekly exception queue, assigns each alert to a trained reviewer, records investigation evidence and disposition, and escalates high-risk alerts immediately and all overdue alerts weekly; Risk performs a monthly closure-quality sample.	STATE 1	Fraud monitoring owner Risk compliance accountable owner	Daily/weekly triage; weekly ageing escalation; monthly quality review	95% of alerts closed within SLA and fewer than 5% unsupported closures in monthly samples.
C-02 A-06 90 days	Close the material control weakness recorded for "Analytics, rules, reports or data checks are used to identify suspicious transactions, behaviour or control exceptions".	The monitoring owner must maintain a rule catalogue in which every test names the fraud scenario it addresses, the data source, the threshold and the reviewing role; tests include duplicate and near-duplicate payments, supplier and employee bank-detail or address matches, unusual approval pairings, dormant-account reactivation and threshold-adjacent transaction clustering; results reconcile to source control totals and rules are tuned monthly from confirmed true and false positives.	STATE 2	Fraud analytics owner Risk compliance accountable owner / Internal Audit	Scheduled rule execution at least monthly; monthly tuning review	All priority fraud scenarios have at least one operating data check, with monthly tuning completed.
C-03 A-10 90 days	Close the material control weakness recorded for "Monitoring covers fraud and control misuse by people inside the organisation".	The monitoring owner must define internal-misuse scenarios for privileged use, overrides, unusual approvals, manual adjustments and other value-bearing activity; reconcile the monitored population to source systems, assign alerts to an independent reviewer and retain disposition and escalation evidence.	STATE 1	Fraud monitoring owner Risk compliance accountable owner	Coverage matrix reviewed at least twice a year and on material change	Every material process has at least one operating indicator for internal misuse and one for external threat where relevant.

ID	OBJECTIVE	RECOMMENDED DESIGN	ASSESSED	OWNER / OVERSIGHT	FREQUENCY	EFFECTIVENESS TEST
C-04 A-19 30 days	Close the material control weakness recorded for "People responsible for monitoring suspicious activity know when to escalate concerns and have authority to do so".	The Risk compliance accountable owner must publish escalation criteria defining what must be escalated, to whom and within what time, grant monitoring staff explicit authority to escalate directly to the fraud-risk executive or Independent governing oversight where a manager is implicated, protect escalators from retaliation, train the monitoring team annually, and review escalation timeliness against criteria each quarter.	STATE 2	Fraud monitoring team lead Independent governing oversight / Fraud-risk executive	Continuous availability; annual training; quarterly timeliness review	100% of qualifying matters escalated within the stated timeframe, with an available conflict-free route.
C-05 A-20 90 days	Close the material control weakness recorded for "Detection controls are periodically reviewed for effectiveness by management, risk, audit or another independent reviewer".	The Independent governing oversight must commission a periodic independent evaluation of detection effectiveness covering coverage against the process fraud maps, data completeness, sample retesting of closed alerts for closure quality, and detection of deliberately seeded test conditions where practical; findings are reported to governance with owners and due dates, and remediation is tracked to closure.	STATE 2	Internal Audit or independent reviewer Independent governing oversight	At least annually, and after material detection change	An independent effectiveness review is completed each period with all findings closed by due date.
C-06 A-11 90 days	Close the material control weakness recorded for "Monitoring covers fraud threats from external parties relevant to the organisation".	The fraud-monitoring owner must identify relevant external-party threats across customer, supplier, partner and provider-operated channels, define required provider reports and data quality checks, reconcile those reports to the organisation's own systems where possible, and route exceptions into owned triage and escalation.	STATE 1	Fraud monitoring and third-party service owners Risk / Information Security	Continuous or scheduled monitoring; monthly provider-coverage review	All relevant external-party channels have defined monitoring or provider-report coverage, with material exceptions triaged within the agreed SLA.
C-12 A-21 30 days	Close the material control weakness recorded for "Roles and decision rights are defined for fraud triage, investigation, escalation and case closure".	The incident-response lead must maintain a decision-rights matrix covering intake, severity, triage, investigation, escalation, disciplinary or recovery referral and closure; conflicts are recorded, independent challenge is available and every decision is retained in the case record.	STATE 2	Fraud incident-response lead Legal / Independent governing oversight	Applied on every case; matrix reviewed annually	100% of cases show a recorded decision-maker and rationale at each defined stage, with recusals applied where required.
C-13 A-04 60 days	Close the material control weakness recorded for "Evidence linked to suspected fraud is identified, preserved and handled appropriately".	The investigation lead opens an evidence register for every material case; trained custodians identify sources, create forensic copies or sealed originals, record hashes/seal numbers, collector/time/location and every transfer, store evidence in access-controlled repositories, and escalate any custody break immediately to Legal.	STATE 1	Investigation lead / Evidence custodian Legal / Compliance	At collection and every transfer; quarterly custody-log review	100% of sampled material-case evidence has a complete custody trail and matching integrity check.
C-14 A-22 60 days	Close the material control weakness recorded for "External specialists are considered when incidents require forensic, legal, cyber or investigative expertise".	The incident-response lead must define engagement triggers such as suspected loss above a threshold, digital forensic imaging requirements, senior-management or governing-body involvement, cross-border elements or likely litigation; pre-qualify providers for forensic accounting, digital forensics and investigative legal support with confidentiality, privilege, data-protection and evidential-standard terms agreed in advance, and record the decision to engage or not engage in every qualifying case.	STATE 2	Fraud incident-response lead Legal / Independent governing oversight	Assessed at triage on every case; provider panel reviewed annually	Every qualifying case records a specialist engagement decision, with providers pre-qualified before use.

ID	OBJECTIVE	RECOMMENDED DESIGN	ASSESSED	OWNER / OVERSIGHT	FREQUENCY	EFFECTIVENESS TEST
C-15 A-23 60 days	Close the material control weakness recorded for "Employees know how to recognise suspected fraud and use the reporting channel".	The ethics owner must publish channel instructions covering how to access it by phone and web, what information helps, whether anonymity is available, what feedback the reporter can expect and the protection from retaliation, in the languages and formats used across operating locations; the channel is tested at least annually with a live submission confirming intake, acknowledgement and case creation, and awareness is measured with targeted follow-up where low.	STATE 2	Ethics / Compliance lead Independent governing oversight	Continuous publication; annual live channel test and awareness measurement	Annual live channel test passes and at least 90% of surveyed staff can describe how to submit a report.
C-16 A-24 60 days	Close the material control weakness recorded for "Relevant external stakeholders have an appropriate way to report suspected fraud or misconduct".	The ethics owner must publish the external reporting route for each relevant stakeholder group, state confidentiality and anti-retaliation protections, restrict access to reports, route concerns away from implicated managers and monitor acknowledgement, triage and escalation times.	STATE 2	Ethics / Compliance lead Independent governing oversight	Continuous intake; monthly case-ageing review; annual channel test	Relevant external stakeholders can find and use the reporting route, with reports acknowledged and triaged within the defined service level.
C-18 A-12 60 days	Close the material control weakness recorded for "Employees are required to disclose and manage conflicts of interest involving suppliers or third parties".	The compliance owner must require annual and on-change declarations from every employee able to influence supplier selection, contracting, receipting or payment, covering directorships, shareholdings, family relationships and outside interests; declarations are tested against the vendor master for matching surnames, addresses, contact details and bank accounts, and every declared or detected conflict receives a documented management action such as recusal, reassignment or enhanced review, recorded in a conflict register.	STATE 1	Compliance with Human Resources Independent governing oversight / Internal Audit	Annual declaration cycle, on-change updates, periodic data matching	At least 98% declaration completion for in-scope roles, with every identified conflict carrying an applied management action.
C-19 A-25 90 days	Close the material control weakness recorded for "The organisation receives and reviews risk information about high-risk third parties managed on its behalf".	The vendor-risk owner must define a risk-based monitoring cycle in which high-risk third parties are re-screened for ownership and sanctions change, reviewed for delivery and quality performance, tested for pricing drift against benchmark or contract, and analysed for spend concentration and unusual growth; findings requiring action are logged with owners, and failure to complete a cycle triggers escalation to the Finance operations accountable owner.	STATE 2	Procurement / Vendor Risk Risk / Internal Audit	Risk-based cycle, at minimum annually for high-risk third parties	100% of high-risk third parties reviewed within the defined cycle with findings actioned by due date.
C-20 A-13 90 days	Close the material control weakness recorded for "Fraud risks are considered when using agents, brokers, distributors, intermediaries, partners or outsourced service providers where relevant".	The relationship owner must ensure every intermediary or outsourced arrangement defines in contract the fraud-control obligations, the limits of delegated authority, the right to audit and obtain records, incident-notification duties and consequences for breach; oversight includes reconciliation of transactions and collections handled on the organisation's behalf, periodic assurance over the provider's relevant controls, and review of any sub-contracting before it occurs.	STATE 1	Relationship owner with Procurement Risk / Legal	At contracting, on renewal, and through periodic reconciliation and assurance	100% of material intermediary arrangements carry fraud-control clauses, reconciliation and periodic assurance.
C-10 A-03 60 days	Close the material control weakness recorded for "Access to sensitive systems, administrator rights and confidential data is restricted".	IT Security must maintain a complete sensitive-access inventory, require named identities and strong authentication, enforce least privilege and session logging, and remove access when the business justification ends; periodic recertification is handled by the separate access-review control.	STATE 1	Identity and Access Management Information Security / Internal Audit	Continuous logging; quarterly recertification; event-driven removal	100% privileged accounts recertified quarterly; leaver access removed within 24 hours; zero unjustified shared admin accounts.

ID	OBJECTIVE	RECOMMENDED DESIGN	ASSESSED	OWNER / OVERSIGHT	FREQUENCY	EFFECTIVENESS TEST
C-11 A-14 60 days	Close the material control weakness recorded for "Sensitive access and administrator rights are reviewed periodically".	IT Security must reconcile the complete sensitive-access and administrator population to current owners and role requirements at least quarterly, obtain an independent keep/remove decision from system owners, record exceptions and close removals within the defined service level; emergency and service accounts are included.	STATE 1	Identity and Access Management Information Security / Internal Audit	Quarterly and after material role or system change	100% of sensitive and administrator access is reviewed each quarter, with removals completed within the defined service level.

Evidence requirement register

What management should be able to produce for each recommended control. No evidence has been requested, received or examined.

Detection and exception review

CONTROL	EVIDENCE REQUIRED	WHAT IT SHOULD PROVE	MINIMUM ACCEPTABLE CHARACTERISTIC	OWNER / RECENCY
C-06	Alert and exception case records	Whether sufficient, attributable evidence is present in the alert and exception case records to test the linked control across the complete in-scope population for the stated period.	Covers relevant external channels and provider reports	Fraud monitoring and third-party service owners Continuous or scheduled monitoring; monthly provider-coverage review
	Coverage and reconciliation checks	Whether sufficient, attributable evidence is present in the coverage and reconciliation checks to test the linked control across the complete in-scope population for the stated period.	Covers relevant external channels and provider reports	Fraud monitoring and third-party service owners Continuous or scheduled monitoring; monthly provider-coverage review
	External-party threat and channel inventory	Whether sufficient, attributable evidence is present in the external-party threat and channel inventory to test the linked control across the complete in-scope population for the stated period.	Covers relevant external channels and provider reports	Fraud monitoring and third-party service owners Continuous or scheduled monitoring; monthly provider-coverage review
	Provider escalation records	Whether sufficient, attributable evidence is present in the provider escalation records to test the linked control across the complete in-scope population for the stated period.	Covers relevant external channels and provider reports	Fraud monitoring and third-party service owners Continuous or scheduled monitoring; monthly provider-coverage review
	Provider monitoring reports	Whether sufficient, attributable evidence is present in the provider monitoring reports to test the linked control across the complete in-scope population for the stated period.	Covers relevant external channels and provider reports	Fraud monitoring and third-party service owners Continuous or scheduled monitoring; monthly provider-coverage review
C-01	Alert investigation log	Whether sufficient, attributable evidence is present in the alert investigation log to test the linked control across the complete in-scope population for the stated period.	Records reviewer, timestamps and rationale	Fraud monitoring owner Daily/weekly triage; weekly ageing escalation; monthly quality review
	Disposition evidence	Whether sufficient, attributable evidence is present in the disposition evidence to test the linked control across the complete in-scope population for the stated period.	Records reviewer, timestamps and rationale	Fraud monitoring owner Daily/weekly triage; weekly ageing escalation; monthly quality review
	Exception population and control totals	Whether sufficient, attributable evidence is present in the exception population and control totals to test the linked control across the complete in-scope population for the stated period.	Records reviewer, timestamps and rationale	Fraud monitoring owner Daily/weekly triage; weekly ageing escalation; monthly quality review
	Monthly quality-review sample	Whether sufficient, attributable evidence is present in the monthly quality-review sample to test the linked control across the complete in-scope population for the stated period.	Records reviewer, timestamps and rationale	Fraud monitoring owner Daily/weekly triage; weekly ageing escalation; monthly quality review
C-05	Closed-alert retesting results	Whether sufficient, attributable evidence is present in the closed-alert retesting results to test the linked control across the complete in-scope population for the stated period.	Findings tracked to evidenced closure	Internal Audit or independent reviewer At least annually, and after material detection change
	Coverage assessment against process fraud maps	Whether sufficient, attributable evidence is present in the coverage assessment against process fraud maps to test the linked control across the complete in-scope population for the stated period.	Findings tracked to evidenced closure	Internal Audit or independent reviewer At least annually, and after material detection change
	Independent review scope and report	Whether sufficient, attributable evidence is present in the independent review scope and report to test the linked control across the complete in-scope population for the stated period.	Findings tracked to evidenced closure	Internal Audit or independent reviewer At least annually, and after material detection change

CONTROL	EVIDENCE REQUIRED	WHAT IT SHOULD PROVE	MINIMUM ACCEPTABLE CHARACTERISTIC	OWNER / RECENCY
	Remediation tracking to closure	Whether sufficient, attributable evidence is present in the remediation tracking to closure to test the linked control across the complete in-scope population for the stated period.	Findings tracked to evidenced closure	Internal Audit or independent reviewer At least annually, and after material detection change
C-03	Coverage report to the fraud forum	Whether sufficient, attributable evidence is present in the coverage report to the fraud forum to test the linked control across the complete in-scope population for the stated period.	Covers every material process	Fraud monitoring owner Coverage matrix reviewed at least twice a year and on material change
	Gap log with owners	Whether sufficient, attributable evidence is present in the gap log with owners to test the linked control across the complete in-scope population for the stated period.	Covers every material process	Fraud monitoring owner Coverage matrix reviewed at least twice a year and on material change
	Indicator definitions for both threat classes	Whether sufficient, attributable evidence is present in the indicator definitions for both threat classes to test the linked control across the complete in-scope population for the stated period.	Covers every material process	Fraud monitoring owner Coverage matrix reviewed at least twice a year and on material change
	Internal versus external coverage matrix	Whether sufficient, attributable evidence is present in the internal versus external coverage matrix to test the linked control across the complete in-scope population for the stated period.	Covers every material process	Fraud monitoring owner Coverage matrix reviewed at least twice a year and on material change
C-04	Evidence of alternate route bypassing implicated management	Whether sufficient, attributable evidence is present in the evidence of alternate route bypassing implicated management to test the linked control across the complete in-scope population for the stated period.	Provides a conflict-free alternate route	Fraud monitoring team lead Continuous availability; annual training; quarterly timeliness review
	Quarterly escalation timeliness review	Whether sufficient, attributable evidence is present in the quarterly escalation timeliness review to test the linked control across the complete in-scope population for the stated period.	Provides a conflict-free alternate route	Fraud monitoring team lead Continuous availability; annual training; quarterly timeliness review
	Training completion records	Whether sufficient, attributable evidence is present in the training completion records to test the linked control across the complete in-scope population for the stated period.	Provides a conflict-free alternate route	Fraud monitoring team lead Continuous availability; annual training; quarterly timeliness review
	Written escalation criteria and routes	Whether sufficient, attributable evidence is present in the written escalation criteria and routes to test the linked control across the complete in-scope population for the stated period.	Provides a conflict-free alternate route	Fraud monitoring team lead Continuous availability; annual training; quarterly timeliness review
C-02	Execution logs and results	Whether sufficient, attributable evidence is present in the execution logs and results to test the linked control across the complete in-scope population for the stated period.	Each rule states scenario, source, threshold and reviewer	Fraud analytics owner Scheduled rule execution at least monthly; monthly tuning review
	Monthly tuning record with true/false positive outcomes	Whether sufficient, attributable evidence is present in the monthly tuning record with true/false positive outcomes to test the linked control across the complete in-scope population for the stated period.	Each rule states scenario, source, threshold and reviewer	Fraud analytics owner Scheduled rule execution at least monthly; monthly tuning review
	Rule and data-check catalogue with scenario linkage	Whether sufficient, attributable evidence is present in the rule and data-check catalogue with scenario linkage to test the linked control across the complete in-scope population for the stated period.	Each rule states scenario, source, threshold and reviewer	Fraud analytics owner Scheduled rule execution at least monthly; monthly tuning review
	Source reconciliation evidence	Whether sufficient, attributable evidence is present in the source reconciliation evidence to test the linked control across the complete in-scope population for the stated period.	Each rule states scenario, source, threshold and reviewer	Fraud analytics owner Scheduled rule execution at least monthly; monthly tuning review

Identity and access challenge

CONTROL	EVIDENCE REQUIRED	WHAT IT SHOULD PROVE	MINIMUM ACCEPTABLE CHARACTERISTIC	OWNER / RECENCY
C-07	Access requests and approvals	Whether sufficient, attributable evidence is present in the access requests and approvals to test the linked control across the complete in-scope population for the stated period.	Approval predates provisioning	Business system owners Quarterly and on every joiner, mover or leaver event
	Current role-to-access matrix	Whether sufficient, attributable evidence is present in the current role-to-access matrix to test the linked controls across the complete in-scope population for the stated period.	Approval predates provisioning	Business system owners Quarterly and on every joiner, mover or leaver event
	Provisioning audit trail	Whether sufficient, attributable evidence is present in the provisioning audit trail to test the linked control across the complete in-scope population for the stated period.	Approval predates provisioning	Business system owners Quarterly and on every joiner, mover or leaver event
	Segregation-of-duties exception decisions	Whether sufficient, attributable evidence is present in the segregation-of-duties exception decisions to test the linked control across the complete in-scope population for the stated period.	Approval predates provisioning	Business system owners Quarterly and on every joiner, mover or leaver event
C-08	Annual coverage and fairness review	Whether sufficient, attributable evidence is present in the annual coverage and fairness review to test the linked control across the complete in-scope population for the stated period.	Applied consistently across comparable roles	Human Resources with process owners Role list reviewed annually; measures applied continuously per role
	Applied oversight measures per role	Whether sufficient, attributable evidence is present in the applied oversight measures per role to test the linked control across the complete in-scope population for the stated period.	Applied consistently across comparable roles	Human Resources with process owners Role list reviewed annually; measures applied continuously per role
	Cover or rotation records	Whether sufficient, attributable evidence is present in the cover or rotation records to test the linked control across the complete in-scope population for the stated period.	Applied consistently across comparable roles	Human Resources with process owners Role list reviewed annually; measures applied continuously per role
	Defined high-risk role list with rationale	Whether sufficient, attributable evidence is present in the defined high-risk role list with rationale to test the linked control across the complete in-scope population for the stated period.	Applied consistently across comparable roles	Human Resources with process owners Role list reviewed annually; measures applied continuously per role
C-10	Approval and business justification	Whether every privileged-access assignment in scope has an approved business justification, a named accountable owner and a documented basis for the level of access granted.	Covers human, service, shared and emergency accounts	Identity and Access Management Continuous logging; quarterly recertification; event-driven removal
	Privileged-account register	Whether the complete privileged-account population is recorded with account type, system, owner, privilege level, status and review date so that unknown or unjustified access can be identified.	Covers human, service, shared and emergency accounts	Identity and Access Management Continuous logging; quarterly recertification; event-driven removal
	Privileged-session/access logs	Whether privileged activity is attributable to named accounts and reviewable for unusual, unauthorised or out-of-pattern activity during the stated period.	Covers human, service, shared and emergency accounts	Identity and Access Management Continuous logging; quarterly recertification; event-driven removal
	Quarterly independent recertification	Whether the complete privileged-access population was independently reviewed on schedule, with explicit keep-or-remove decisions and unresolved exceptions identified.	Covers human, service, shared and emergency accounts	Identity and Access Management Continuous logging; quarterly recertification; event-driven removal
	Removal tickets	Whether access removals identified through recertification, role change or leaver events were completed within the required service level and are traceable to closure evidence.	Covers human, service, shared and emergency accounts	Identity and Access Management Continuous logging; quarterly recertification; event-driven removal

CONTROL	EVIDENCE REQUIRED	WHAT IT SHOULD PROVE	MINIMUM ACCEPTABLE CHARACTERISTIC	OWNER / REGENCY
C-11	Complete sensitive-access register	Whether sufficient, attributable evidence is present in the complete sensitive-access register to test the linked control across the complete in-scope population for the stated period.	Reconciles to the complete population	Identity and Access Management Quarterly and after material role or system change
	Quarterly recertification decisions	Whether sufficient, attributable evidence is present in the quarterly recertification decisions to test the linked control across the complete in-scope population for the stated period.	Reconciles to the complete population	Identity and Access Management Quarterly and after material role or system change
	Role and business-justification evidence	Whether sufficient, attributable evidence is present in the role and business-justification evidence to test the linked control across the complete in-scope population for the stated period.	Reconciles to the complete population	Identity and Access Management Quarterly and after material role or system change
C-09	Complete user-access export	Whether sufficient, attributable evidence is present in the complete user-access export to test the linked control across the complete in-scope population for the stated period.	Covers the complete active-user population	Business system owners Quarterly and on every joiner, mover or leaver event
	Periodic review decisions	Whether sufficient, attributable evidence is present in the periodic review decisions to test the linked control across the complete in-scope population for the stated period.	Covers the complete active-user population	Business system owners Quarterly and on every joiner, mover or leaver event
	Removal and exception tickets	Whether sufficient, attributable evidence is present in the removal and exception tickets to test the linked controls across the complete in-scope population for the stated period.	Covers the complete active-user population	Business system owners / Identity and Access Management Quarterly and after material role or system change; Quarterly and on every joiner, mover or leaver event

Incident response and evidence integrity

CONTROL	EVIDENCE REQUIRED	WHAT IT SHOULD PROVE	MINIMUM ACCEPTABLE CHARACTERISTIC	OWNER / REGENCY
C-16	Acknowledgement and escalation records	Whether sufficient, attributable evidence is present in the acknowledgement and escalation records to test the linked control across the complete in-scope population for the stated period.	Covers the relevant external stakeholder population	Ethics / Compliance lead Continuous intake; monthly case-ageing review; annual channel test
	Anonymised case register	Whether sufficient, attributable evidence is present in the anonymised case register to test the linked control across the complete in-scope population for the stated period.	Covers the relevant external stakeholder population	Ethics / Compliance lead Continuous intake; monthly case-ageing review; annual channel test
	Channel availability test	Whether sufficient, attributable evidence is present in the channel availability test to test the linked control across the complete in-scope population for the stated period.	Covers the relevant external stakeholder population	Ethics / Compliance lead Continuous intake; monthly case-ageing review; annual channel test
C-15	Published external reporting routes	Whether sufficient, attributable evidence is present in the published external reporting routes to test the linked control across the complete in-scope population for the stated period.	Covers the relevant external stakeholder population	Ethics / Compliance lead Continuous intake; monthly case-ageing review; annual channel test
	Annual live channel test record	Whether sufficient, attributable evidence is present in the annual live channel test record to test the linked control across the complete in-scope population for the stated period.	Available in the languages and formats staff actually use	Ethics / Compliance lead Continuous publication; annual live channel test and awareness measurement

CONTROL	EVIDENCE REQUIRED	WHAT IT SHOULD PROVE	MINIMUM ACCEPTABLE CHARACTERISTIC	OWNER / RECENCY
	Awareness measurement results	Whether sufficient, attributable evidence is present in the awareness measurement results to test the linked control across the complete in-scope population for the stated period.	Available in the languages and formats staff actually use	Ethics / Compliance lead Continuous publication; annual live channel test and awareness measurement
	Follow-up communication where awareness was low	Whether sufficient, attributable evidence is present in the follow-up communication where awareness was low to test the linked control across the complete in-scope population for the stated period.	Available in the languages and formats staff actually use	Ethics / Compliance lead Continuous publication; annual live channel test and awareness measurement
	Published channel instructions in relevant languages and formats	Whether sufficient, attributable evidence is present in the published channel instructions in relevant languages and formats to test the linked control across the complete in-scope population for the stated period.	Available in the languages and formats staff actually use	Ethics / Compliance lead Continuous publication; annual live channel test and awareness measurement
C-12	Case-closure approvals	Whether sufficient, attributable evidence is present in the case-closure approvals to test the linked control across the complete in-scope population for the stated period.	Names a decision owner for every stage	Fraud incident-response lead Applied on every case; matrix reviewed annually
	Fraud case decision-rights matrix	Whether sufficient, attributable evidence is present in the fraud case decision-rights matrix to test the linked control across the complete in-scope population for the stated period.	Names a decision owner for every stage	Fraud incident-response lead Applied on every case; matrix reviewed annually
	Role and conflict declarations	Whether sufficient, attributable evidence is present in the role and conflict declarations to test the linked control across the complete in-scope population for the stated period.	Names a decision owner for every stage	Fraud incident-response lead Applied on every case; matrix reviewed annually
	Triage and escalation records	Whether sufficient, attributable evidence is present in the triage and escalation records to test the linked control across the complete in-scope population for the stated period.	Names a decision owner for every stage	Fraud incident-response lead Applied on every case; matrix reviewed annually
C-13	Chain-of-custody forms	Whether each transfer of material evidence records custody, timing and handover without unexplained gaps.	Hash or seal reconciles at handover	Investigation lead / Evidence custodian At collection and every transfer; quarterly custody-log review
	Evidence register	Whether all material evidence items are uniquely recorded, assigned and traceable through the case.	Hash or seal reconciles at handover	Investigation lead / Evidence custodian At collection and every transfer; quarterly custody-log review
	Hash or seal records	Whether collected evidence has integrity markers that can be matched at later custody points.	Hash or seal reconciles at handover	Investigation lead / Evidence custodian At collection and every transfer; quarterly custody-log review
	Repository access log	Whether access to preserved evidence is restricted, attributable and reviewable.	Hash or seal reconciles at handover	Investigation lead / Evidence custodian At collection and every transfer; quarterly custody-log review
	Retention/legal-hold instruction	Whether preservation instructions define the required retention or legal-hold treatment for relevant records.	Hash or seal reconciles at handover	Investigation lead / Evidence custodian At collection and every transfer; quarterly custody-log review
C-14	Confidentiality and evidential-standard clauses	Whether sufficient, attributable evidence is present in the confidentiality and evidential-standard clauses to test the linked control across the complete in-scope population for the stated period.	Providers pre-qualified before an incident, not during one	Fraud incident-response lead Assessed at triage on every case; provider panel reviewed annually

CONTROL	EVIDENCE REQUIRED	WHAT IT SHOULD PROVE	MINIMUM ACCEPTABLE CHARACTERISTIC	OWNER / REGENCY
	Engagement or non-engagement decision per qualifying case	Whether sufficient, attributable evidence is present in the engagement or non-engagement decision per qualifying case to test the linked control across the complete in-scope population for the stated period.	Providers pre-qualified before an incident, not during one	Fraud incident-response lead Assessed at triage on every case; provider panel reviewed annually
	Pre-qualified provider list with agreed terms	Whether sufficient, attributable evidence is present in the pre-qualified provider list with agreed terms to test the linked control across the complete in-scope population for the stated period.	Providers pre-qualified before an incident, not during one	Fraud incident-response lead Assessed at triage on every case; provider panel reviewed annually
	Written engagement trigger criteria	Whether sufficient, attributable evidence is present in the written engagement trigger criteria to test the linked control across the complete in-scope population for the stated period.	Providers pre-qualified before an incident, not during one	Fraud incident-response lead Assessed at triage on every case; provider panel reviewed annually

Supplier and payment integrity

CONTROL	EVIDENCE REQUIRED	WHAT IT SHOULD PROVE	MINIMUM ACCEPTABLE CHARACTERISTIC	OWNER / REGENCY
C-19	Action log with owners	Whether sufficient, attributable evidence is present in the action log with owners to test the linked control across the complete in-scope population for the stated period.	Covers the complete high-risk population	Procurement / Vendor Risk Risk-based cycle, at minimum annually for high-risk third parties
	Performance and pricing review records	Whether sufficient, attributable evidence is present in the performance and pricing review records to test the linked control across the complete in-scope population for the stated period.	Covers the complete high-risk population	Procurement / Vendor Risk Risk-based cycle, at minimum annually for high-risk third parties
	Re-screening results for ownership and sanctions	Whether sufficient, attributable evidence is present in the re-screening results for ownership and sanctions to test the linked control across the complete in-scope population for the stated period.	Covers the complete high-risk population	Procurement / Vendor Risk Risk-based cycle, at minimum annually for high-risk third parties
	Risk-tiered monitoring schedule	Whether sufficient, attributable evidence is present in the risk-tiered monitoring schedule to test the linked control across the complete in-scope population for the stated period.	Covers the complete high-risk population	Procurement / Vendor Risk Risk-based cycle, at minimum annually for high-risk third parties
	Spend concentration analysis	Whether sufficient, attributable evidence is present in the spend concentration analysis to test the linked control across the complete in-scope population for the stated period.	Covers the complete high-risk population	Procurement / Vendor Risk Risk-based cycle, at minimum annually for high-risk third parties
C-20	Assurance over provider controls	Whether sufficient, attributable evidence is present in the assurance over provider controls to test the linked control across the complete in-scope population for the stated period.	Contract states audit rights and authority limits explicitly	Relationship owner with Procurement At contracting, on renewal, and through periodic reconciliation and assurance
	Contract clauses covering fraud controls, audit rights and delegated authority limits	Whether sufficient, attributable evidence is present in the contract clauses covering fraud controls, audit rights and delegated authority limits to test the linked control across the complete in-scope population for the stated period.	Contract states audit rights and authority limits explicitly	Relationship owner with Procurement At contracting, on renewal, and through periodic reconciliation and assurance
	Reconciliation of intermediary-handled transactions or collections	Whether sufficient, attributable evidence is present in the reconciliation of intermediary-handled transactions or collections to test the linked control across the complete in-scope population for the stated period.	Contract states audit rights and authority limits explicitly	Relationship owner with Procurement At contracting, on renewal, and through periodic reconciliation and assurance

CONTROL	EVIDENCE REQUIRED	WHAT IT SHOULD PROVE	MINIMUM ACCEPTABLE CHARACTERISTIC	OWNER / REGENCY
	Sub-contracting approvals	Whether sufficient, attributable evidence is present in the sub-contracting approvals to test the linked control across the complete in-scope population for the stated period.	Contract states audit rights and authority limits explicitly	Relationship owner with Procurement At contracting, on renewal, and through periodic reconciliation and assurance
C-17	Beneficial-ownership/conflict screening	Whether proposed suppliers are screened for ownership and conflict indicators before activation and any exceptions are resolved or approved.	Covers the full supplier population added in the period	Procurement / Vendor Master Before every supplier activation; annual refresh for high-risk suppliers
	Completed onboarding checklist	Whether the required supplier due-diligence checks were completed before activation for the in-scope supplier population.	Covers the full supplier population added in the period	Procurement / Vendor Master Before every supplier activation; annual refresh for high-risk suppliers
	Independent registration and bank verification	Whether supplier legal identity and bank-account ownership were independently verified before activation or payment.	Covers the full supplier population added in the period	Procurement / Vendor Master Before every supplier activation; annual refresh for high-risk suppliers
	Second-reviewer approval	Whether supplier activation or another high-risk change received the required independent second-person approval before release.	Covers the full supplier population added in the period	Procurement / Vendor Master Before every supplier activation; annual refresh for high-risk suppliers
C-18	Conflict register with management actions	Whether sufficient, attributable evidence is present in the conflict register with management actions to test the linked control across the complete in-scope population for the stated period.	Covers all roles able to influence selection or payment	Compliance with Human Resources Annual declaration cycle, on-change updates, periodic data matching
	Data-matching results against the vendor master	Whether sufficient, attributable evidence is present in the data-matching results against the vendor master to test the linked control across the complete in-scope population for the stated period.	Covers all roles able to influence selection or payment	Compliance with Human Resources Annual declaration cycle, on-change updates, periodic data matching
	Declaration register covering all in-scope roles	Whether sufficient, attributable evidence is present in the declaration register covering all in-scope roles to test the linked control across the complete in-scope population for the stated period.	Covers all roles able to influence selection or payment	Compliance with Human Resources Annual declaration cycle, on-change updates, periodic data matching
	Evidence of recusal or enhanced review being applied	Whether sufficient, attributable evidence is present in the evidence of recusal or enhanced review being applied to test the linked control across the complete in-scope population for the stated period.	Covers all roles able to influence selection or payment	Compliance with Human Resources Annual declaration cycle, on-change updates, periodic data matching

Fraud governance and risk identification

CONTROL	EVIDENCE REQUIRED	WHAT IT SHOULD PROVE	MINIMUM ACCEPTABLE CHARACTERISTIC	OWNER / REGENCY
C-22	Approved delegation of authority matrix	Whether sufficient, attributable evidence is present in the approved delegation of authority matrix to test the linked control across the complete in-scope population for the stated period.	Approver independence is demonstrable from system records	Finance and operational process owners Every qualifying transaction; monthly splitting and override review
	Monthly split-transaction and override report	Whether sufficient, attributable evidence is present in the monthly split-transaction and override report to test the linked control across the complete in-scope population for the stated period.	Approver independence is demonstrable from system records	Finance and operational process owners Every qualifying transaction; monthly splitting and override review

CONTROL	EVIDENCE REQUIRED	WHAT IT SHOULD PROVE	MINIMUM ACCEPTABLE CHARACTERISTIC	OWNER / RECENCY
	Sample of approvals showing independence	Whether sufficient, attributable evidence is present in the sample of approvals showing independence to test the linked control across the complete in-scope population for the stated period.	Approver independence is demonstrable from system records	Finance and operational process owners Every qualifying transaction; monthly splitting and override review
	System configuration enforcing thresholds	Whether sufficient, attributable evidence is present in the system configuration enforcing thresholds to test the linked control across the complete in-scope population for the stated period.	Approver independence is demonstrable from system records	Finance and operational process owners Every qualifying transaction; monthly splitting and override review
C-21	Control linkage showing preventive and detective controls	Whether each mapped fraud scenario is linked to named preventive and detective controls, with residual gaps identifiable.	Identifies the roles and permissions able to execute each scenario	Risk compliance accountable owner with named process owners Refreshed with the fraud risk assessment and on material process change
	Per-process fraud scenario map	Whether each material process has explicit fraud scenarios, relevant roles or permissions and residual exposure documented.	Identifies the roles and permissions able to execute each scenario	Risk compliance accountable owner with named process owners Refreshed with the fraud risk assessment and on material process change
	Process inventory identifying material value-bearing processes	Whether the complete population of material value-bearing processes has been identified before fraud-risk mapping is assessed.	Identifies the roles and permissions able to execute each scenario	Risk compliance accountable owner with named process owners Refreshed with the fraud risk assessment and on material process change
	Process-owner sign-off	Whether process owners have reviewed and accepted the mapped fraud scenarios, control ownership and residual gaps.	Identifies the roles and permissions able to execute each scenario	Risk compliance accountable owner with named process owners Refreshed with the fraud risk assessment and on material process change

Payroll integrity

CONTROL	EVIDENCE REQUIRED	WHAT IT SHOULD PROVE	MINIMUM ACCEPTABLE CHARACTERISTIC	OWNER / RECENCY
C-23	Duplicate and ghost-record exception report	Whether sufficient, attributable evidence is present in the duplicate and ghost-record exception report to test the linked control across the complete in-scope population for the stated period.	Covers the complete payment-run population	Payroll and Human Resources Before every payroll payment run; monthly trend review
	Exception closure evidence	Whether sufficient, attributable evidence is present in the exception closure evidence to test the linked control across the complete in-scope population for the stated period.	Covers the complete payment-run population	Payroll and Human Resources Before every payroll payment run; monthly trend review
	Joiner/mover/leaver reconciliation	Whether sufficient, attributable evidence is present in the joiner/mover/leaver reconciliation to test the linked control across the complete in-scope population for the stated period.	Covers the complete payment-run population	Payroll and Human Resources Before every payroll payment run; monthly trend review
	Payroll master-file change report	Whether sufficient, attributable evidence is present in the payroll master-file change report to test the linked control across the complete in-scope population for the stated period.	Covers the complete payment-run population	Payroll and Human Resources Before every payroll payment run; monthly trend review
	Pre-payroll review sign-off	Whether sufficient, attributable evidence is present in the pre-payroll review sign-off to test the linked control across the complete in-scope population for the stated period.	Covers the complete payment-run population	Payroll and Human Resources Before every payroll payment run; monthly trend review

Cash custody and reconciliation

CONTROL	EVIDENCE REQUIRED	WHAT IT SHOULD PROVE	MINIMUM ACCEPTABLE CHARACTERISTIC	OWNER / RECENCY
C-24	Banking and receipt reconciliation	Whether sufficient, attributable evidence is present in the banking and receipt reconciliation to test the linked control across the complete in-scope population for the stated period.	Counts are attributable and time-stamped	Site operations and Finance Each cash-handling shift/day; monthly exception and trend review
	Cash custody register	Whether sufficient, attributable evidence is present in the cash custody register to test the linked control across the complete in-scope population for the stated period.	Counts are attributable and time-stamped	Site operations and Finance Each cash-handling shift/day; monthly exception and trend review
	Count sheets and independent checks	Whether sufficient, attributable evidence is present in the count sheets and independent checks to test the linked control across the complete in-scope population for the stated period.	Counts are attributable and time-stamped	Site operations and Finance Each cash-handling shift/day; monthly exception and trend review
	Sealed transfer records	Whether sufficient, attributable evidence is present in the sealed transfer records to test the linked control across the complete in-scope population for the stated period.	Counts are attributable and time-stamped	Site operations and Finance Each cash-handling shift/day; monthly exception and trend review
	Shortage/overage investigation log	Whether sufficient, attributable evidence is present in the shortage/overage investigation log to test the linked control across the complete in-scope population for the stated period.	Counts are attributable and time-stamped	Site operations and Finance Each cash-handling shift/day; monthly exception and trend review

Stock and physical-asset integrity

CONTROL	EVIDENCE REQUIRED	WHAT IT SHOULD PROVE	MINIMUM ACCEPTABLE CHARACTERISTIC	OWNER / RECENCY
C-25	Complete stock and asset register	Whether sufficient, attributable evidence is present in the complete stock and asset register to test the linked control across the complete in-scope population for the stated period.	Count differences and write-offs have independent review	Operations, Stores and Asset Management Movement on each event; periodic counts; monthly exception review
	Count sheets and reconciliation	Whether sufficient, attributable evidence is present in the count sheets and reconciliation to test the linked control across the complete in-scope population for the stated period.	Count differences and write-offs have independent review	Operations, Stores and Asset Management Movement on each event; periodic counts; monthly exception review
	Custodian assignments	Whether sufficient, attributable evidence is present in the custodian assignments to test the linked control across the complete in-scope population for the stated period.	Count differences and write-offs have independent review	Operations, Stores and Asset Management Movement on each event; periodic counts; monthly exception review
	Movement and disposal records	Whether sufficient, attributable evidence is present in the movement and disposal records to test the linked control across the complete in-scope population for the stated period.	Count differences and write-offs have independent review	Operations, Stores and Asset Management Movement on each event; periodic counts; monthly exception review
	Write-off and shrinkage review	Whether sufficient, attributable evidence is present in the write-off and shrinkage review to test the linked control across the complete in-scope population for the stated period.	Count differences and write-offs have independent review	Operations, Stores and Asset Management Movement on each event; periodic counts; monthly exception review

12-month action and assurance register

The full twelve-month programme. Not every row is initial implementation: later horizons operate each control through its required cycle and then review whether it is still effective. The work type on each row says which it is.

HORIZON	WORK TYPE	ACTION	OWNER	COMPLETION CRITERION	EFFECTIVENESS MEASURE
30 days	Implement	Apply immediate escalation at "A qualifying matter escalated late, or an escalation routed only through an implicated manager." and deliver the exact control design: The Risk compliance accountable owner must publish escalation criteria defining what must be escalated, to whom and within what time, grant monitoring staff explicit authority to escalate directly to the fraud-risk executive or Independent governing oversight where a manager is implicated, protect escalators from retaliation, train the monitoring team annually, and review escalation timeliness against criteria each quarter.	Risk compliance accountable owner	Evidence of alternate route bypassing implicated management; Quarterly escalation timeliness review; Training completion records; Written escalation criteria and routes	100% of qualifying matters escalated within the stated timeframe, with an available conflict-free route.
30 days	Implement	Apply immediate escalation at "A case decision taken by an implicated party, or a stage with no recorded decision-maker." and deliver the exact control design: The incident-response lead must maintain a decision-rights matrix covering intake, severity, triage, investigation, escalation, disciplinary or recovery referral and closure; conflicts are recorded, independent challenge is available and every decision is retained in the case record.	Operations accountable owner / Legal investigations accountable owner	Case-closure approvals; Fraud case decision-rights matrix; Role and conflict declarations; Triage and escalation records	100% of cases show a recorded decision-maker and rationale at each defined stage, with recusals applied where required.
60 days	Implement	Apply immediate escalation at "Any supplier activated before verification or any ownership/conflict match unresolved." and deliver the exact control design: Procurement performs a pre-activation checklist across every proposed supplier, independently verifies registration and bank ownership, screens beneficial owners and conflicts, risk-rates the supplier, and blocks ERP activation until a second reviewer signs; the vendor master retains the evidence package.	Finance and operations accountable owner	Beneficial-ownership/conflict screening; Completed onboarding checklist; Independent registration and bank verification; Second-reviewer approval	100% of newly activated suppliers have a complete, pre-activation evidence pack and independent approval.
60 days	Implement	Apply immediate escalation at "Any unexplained custody gap, integrity mismatch or unauthorised repository access." and deliver the exact control design: The investigation lead opens an evidence register for every material case; trained custodians identify sources, create forensic copies or sealed originals, record hashes/seal numbers, collector/time/location and every transfer, store evidence in access-controlled repositories, and escalate any custody break immediately to Legal.	Legal investigations accountable owner / Operations accountable owner	Chain-of-custody forms; Evidence register; Hash or seal records; Repository access log; Retention/legal-hold instruction	100% of sampled material-case evidence has a complete custody trail and matching integrity check.

HORIZON	WORK TYPE	ACTION	OWNER	COMPLETION CRITERION	EFFECTIVENESS MEASURE
60 days	Implement	Apply immediate escalation at "Any missed quarterly review, unassigned account or removal overdue beyond 10 business days." and deliver the exact control design: System owners must maintain a current role-to-access matrix, require business-owner approval against the requester's current duties before granting access, separate incompatible initiation and approval rights, and retain the request, approval and provisioning trail.	Operations accountable owner	Access requests and approvals; Current role-to-access matrix; Provisioning audit trail; Segregation-of-duties exception decisions	100% population reviewed quarterly and 95% of removal exceptions closed within 10 business days.
60 days	Implement	Apply immediate escalation at "Any unknown or unjustified privileged account, missed recertification or leaver access beyond 24 hours." and deliver the exact control design: IT Security must maintain a complete sensitive-access inventory, require named identities and strong authentication, enforce least privilege and session logging, and remove access when the business justification ends; periodic recertification is handled by the separate access-review control.	Technology security accountable owner	Approval and business justification; Privileged-account register; Privileged-session/access logs; Quarterly independent recertification; Removal tickets	100% privileged accounts recertified quarterly; leaver access removed within 24 hours; zero unjustified shared admin accounts.
60 days	Implement	Apply immediate escalation at "Any above-threshold release without independent approval, or a repeated splitting pattern by the same initiator." and deliver the exact control design: The Finance operations accountable owner must approve a delegation of authority matrix setting value and risk thresholds by transaction type, configure the finance and operational systems to block release above threshold without a second independent approver, prohibit self-approval and approval by direct reports of the initiator, and run a monthly report for split transactions falling just below thresholds and for any threshold override.	Finance operations accountable owner	Approved delegation of authority matrix; Monthly split-transaction and override report; Sample of approvals showing independence; System configuration enforcing thresholds	100% of above-threshold transactions carry an independent second approval, with all overrides reviewed monthly.
60 days	Implement	Apply immediate escalation at "Any high-risk alert unassigned after one business day or SLA breach rate above 5%." and deliver the exact control design: The monitoring owner generates a complete daily or weekly exception queue, assigns each alert to a trained reviewer, records investigation evidence and disposition, and escalates high-risk alerts immediately and all overdue alerts weekly; Risk performs a monthly closure-quality sample.	Finance and operations accountable owner	Alert investigation log; Disposition evidence; Exception population and control totals; Monthly quality-review sample	95% of alerts closed within SLA and fewer than 5% unsupported closures in monthly samples.
60 days	Implement	Apply immediate escalation at "An employee-supplier match not investigated, or a declared conflict with no management action." and deliver the exact control design: The compliance owner must require annual and on-change declarations from every employee able to influence supplier selection, contracting, receipting or payment, covering directorships, shareholdings, family relationships and outside interests; declarations are tested against the vendor master for matching surnames, addresses, contact details and bank accounts, and every declared or detected conflict receives a documented management action such as recusal, reassignment or enhanced review, recorded in a conflict register.	Finance operations accountable owner / Legal investigations accountable owner	Conflict register with management actions; Data-matching results against the vendor master; Declaration register covering all in-scope roles; Evidence of recusal or enhanced review being applied	At least 98% declaration completion for in-scope roles, with every identified conflict carrying an applied management action.

HORIZON	WORK TYPE	ACTION	OWNER	COMPLETION CRITERION	EFFECTIVENESS MEASURE
60 days	Implement	Apply immediate escalation at "Unknown or unjustified access, missed review, or removal overdue beyond the agreed service level." and deliver the exact control design: IT Security must reconcile the complete sensitive-access and administrator population to current owners and role requirements at least quarterly, obtain an independent keep/remove decision from system owners, record exceptions and close removals within the defined service level; emergency and service accounts are included.	Technology security accountable owner	Complete sensitive-access register; Quarterly recertification decisions; Removal and exception tickets; Role and business-justification evidence	100% of sensitive and administrator access is reviewed each quarter, with removals completed within the defined service level.
60 days	Implement	Apply immediate escalation at "Missed review, unknown access or removal overdue beyond the defined service level." and deliver the exact control design: System owners must export the complete active-user access population on a defined cycle, obtain business-owner keep/remove decisions against current responsibilities, route exceptions to IT for closure and reconcile leaver and mover removals to the HR feed.	Operations accountable owner	Complete user-access export; Current role-to-access matrix; Periodic review decisions; Removal and exception tickets	100% of ordinary system and data access is reviewed on schedule and stale access is removed within the defined service level.
60 days	Implement	Apply immediate escalation at "A sensitive payroll change released without review, unexplained duplicate or ghost record, or unresolved exception at payment release." and deliver the exact control design: Payroll and Human Resources must reconcile joiner, mover and leaver records to the payroll master file before each payment run, independently review bank-account and pay-rate changes, test for duplicate or ghost records and unusual payments, and retain reviewer decisions and exception closure before release.	Finance operations accountable owner / People workforce accountable owner	Duplicate and ghost-record exception report; Exception closure evidence; Joiner/mover/leaver reconciliation; Payroll master-file change report; Pre-payroll review sign-off	Every payroll run has a completed independent pre-payment review with all exceptions resolved or formally escalated.
60 days	Implement	Apply immediate escalation at "Unexplained shortage or overage above threshold, missing count or unreconciled banking." and deliver the exact control design: Finance and site managers must assign cash custodians, perform opening and closing counts with independent review, reconcile takings to receipts and bankings, record sealed transfers and investigate every shortage or overage against a defined threshold before the next cycle closes.	Finance and operations accountable owner	Banking and receipt reconciliation; Cash custody register; Count sheets and independent checks; Sealed transfer records; Shortage/overage investigation log	All cash points reconcile each cycle, with every difference investigated and resolved or escalated within the defined period.
60 days	Implement	Apply immediate escalation at "A qualifying case handled internally without a recorded decision, or forensic imaging attempted without competent capability." and deliver the exact control design: The incident-response lead must define engagement triggers such as suspected loss above a threshold, digital forensic imaging requirements, senior-management or governing-body involvement, cross-border elements or likely litigation; pre-qualify providers for forensic accounting, digital forensics and investigative legal support with confidentiality, privilege, data-protection and evidential-standard terms agreed in advance, and record the decision to engage or not engage in every qualifying case.	Legal investigations accountable owner / Finance operations accountable owner	Confidentiality and evidential-standard clauses; Engagement or non-engagement decision per qualifying case; Pre-qualified provider list with agreed terms; Written engagement trigger criteria	Every qualifying case records a specialist engagement decision, with providers pre-qualified before use.

HORIZON	WORK TYPE	ACTION	OWNER	COMPLETION CRITERION	EFFECTIVENESS MEASURE
60 days	Implement	Apply immediate escalation at "A failed channel test, or a site or language group below the awareness threshold." and deliver the exact control design: The ethics owner must publish channel instructions covering how to access it by phone and web, what information helps, whether anonymity is available, what feedback the reporter can expect and the protection from retaliation, in the languages and formats used across operating locations; the channel is tested at least annually with a live submission confirming intake, acknowledgement and case creation, and awareness is measured with targeted follow-up where low.	People workforce accountable owner	Annual live channel test record; Awareness measurement results; Follow-up communication where awareness was low; Published channel instructions in relevant languages and formats	Annual live channel test passes and at least 90% of surveyed staff can describe how to submit a report.
60 days	Implement	Apply immediate escalation at "A relevant stakeholder group has no suitable route, the channel is unavailable or a report is not independently triaged." and deliver the exact control design: The ethics owner must publish the external reporting route for each relevant stakeholder group, state confidentiality and anti-retaliation protections, restrict access to reports, route concerns away from implicated managers and monitor acknowledgement, triage and escalation times.	Independent governing oversight / CEO	Acknowledgement and escalation records; Anonymised case register; Channel availability test; Published external reporting routes	Relevant external stakeholders can find and use the reporting route, with reports acknowledged and triaged within the defined service level.
90 days	Implement	Apply immediate escalation at "Any material process unmapped, or a mapped residual gap with no owner." and deliver the exact control design: The Risk compliance accountable owner must produce a process-by-process fraud map covering every material value-bearing process: for each, record the fraud scenarios, the roles and system permissions able to execute them alone or in collusion, the preventive and detective controls relied upon, and the residual gap; process owners sign their own map, and any process without a mapped control owner escalates to the fraud-risk executive.	Finance and operations accountable owner	Control linkage showing preventive and detective controls; Per-process fraud scenario map; Process inventory identifying material value-bearing processes; Process-owner sign-off	100% of material value-bearing processes have a signed fraud map with named controls and residual gaps.
90 days	Implement	Apply immediate escalation at "A priority scenario with no operating check, or rules unexecuted for a full cycle." and deliver the exact control design: The monitoring owner must maintain a rule catalogue in which every test names the fraud scenario it addresses, the data source, the threshold and the reviewing role; tests include duplicate and near-duplicate payments, supplier and employee bank-detail or address matches, unusual approval pairings, dormant-account reactivation and threshold-adjacent transaction clustering; results reconcile to source control totals and rules are tuned monthly from confirmed true and false positives.	Finance operations accountable owner / Technology security accountable owner	Execution logs and results; Monthly tuning record with true/false positive outcomes; Rule and data-check catalogue with scenario linkage; Source reconciliation evidence	All priority fraud scenarios have at least one operating data check, with monthly tuning completed.

HORIZON	WORK TYPE	ACTION	OWNER	COMPLETION CRITERION	EFFECTIVENESS MEASURE
90 days	Implement	Apply immediate escalation at "A high-risk role with no operating measure, or a sole operator with no cover period in twelve months." and deliver the exact control design: Human Resources and the Risk compliance accountable owner must jointly define high-risk roles by authority, system access and asset custody, and apply documented measures to each: secondary review of sensitive outputs, periodic rotation or cross-training, a block-leave or cover period during which another person performs the duties, and enhanced transaction monitoring; measures are applied consistently, recorded, and reviewed annually for coverage and fairness.	Operations accountable owner / People workforce accountable owner	Annual coverage and fairness review; Applied oversight measures per role; Cover or rotation records; Defined high-risk role list with rationale	Every identified high-risk role has at least one evidenced compensating measure operating in the period.
90 days	Implement	Apply immediate escalation at "A material process with monitoring on only one threat class and no logged gap owner." and deliver the exact control design: The monitoring owner must define internal-misuse scenarios for privileged use, overrides, unusual approvals, manual adjustments and other value-bearing activity; reconcile the monitored population to source systems, assign alerts to an independent reviewer and retain disposition and escalation evidence.	Finance operations accountable owner / Technology security accountable owner	Coverage report to the fraud forum; Gap log with owners; Indicator definitions for both threat classes; Internal versus external coverage matrix	Every material process has at least one operating indicator for internal misuse and one for external threat where relevant.
90 days	Implement	Apply immediate escalation at "Missing provider report, unexplained coverage gap or material external-party alert outside SLA." and deliver the exact control design: The fraud-monitoring owner must identify relevant external-party threats across customer, supplier, partner and provider-operated channels, define required provider reports and data quality checks, reconcile those reports to the organisation's own systems where possible, and route exceptions into owned triage and escalation.	Operations accountable owner / Technology security accountable owner	Alert and exception case records; Coverage and reconciliation checks; External-party threat and channel inventory; Provider escalation records; Provider monitoring reports	All relevant external-party channels have defined monitoring or provider-report coverage, with material exceptions triaged within the agreed SLA.
90 days	Implement	Apply immediate escalation at "An intermediary operating without contractual fraud obligations, undisclosed sub-contracting, or unreconciled delegated collections." and deliver the exact control design: The relationship owner must ensure every intermediary or outsourced arrangement defines in contract the fraud-control obligations, the limits of delegated authority, the right to audit and obtain records, incident-notification duties and consequences for breach; oversight includes reconciliation of transactions and collections handled on the organisation's behalf, periodic assurance over the provider's relevant controls, and review of any sub-contracting before it occurs.	Finance and operations accountable owner	Assurance over provider controls; Contract clauses covering fraud controls, audit rights and delegated authority limits; Reconciliation of intermediary-handled transactions or collections; Sub-contracting approvals	100% of material intermediary arrangements carry fraud-control clauses, reconciliation and periodic assurance.

HORIZON	WORK TYPE	ACTION	OWNER	COMPLETION CRITERION	EFFECTIVENESS MEASURE
90 days	Implement	Apply immediate escalation at "Material unexplained shrinkage, unsupported disposal or missed count at a high-risk location." and deliver the exact control design: Operations and Finance must maintain a complete stock and asset register, assign custodians, require authorised movement and disposal records, perform risk-based counts across locations, reconcile results to the ledger or inventory system and independently approve write-offs and investigate shrinkage exceptions.	Finance and operations accountable owner	Complete stock and asset register; Count sheets and reconciliation; Custodian assignments; Movement and disposal records; Write-off and shrinkage review	All material stock and physical assets are counted and reconciled on schedule, with shrinkage and write-offs independently reviewed.
90 days	Implement	Apply immediate escalation at "Review overdue, or a finding overdue beyond its due date without governance escalation." and deliver the exact control design: The Independent governing oversight must commission a periodic independent evaluation of detection effectiveness covering coverage against the process fraud maps, data completeness, sample retesting of closed alerts for closure quality, and detection of deliberately seeded test conditions where practical; findings are reported to governance with owners and due dates, and remediation is tracked to closure.	Independent governing oversight	Closed-alert retesting results; Coverage assessment against process fraud maps; Independent review scope and report; Remediation tracking to closure	An independent effectiveness review is completed each period with all findings closed by due date.
90 days	Implement	Apply immediate escalation at "A high-risk third party overdue for review, or an ownership change detected without reassessment." and deliver the exact control design: The vendor-risk owner must define a risk-based monitoring cycle in which high-risk third parties are re-screened for ownership and sanctions change, reviewed for delivery and quality performance, tested for pricing drift against benchmark or contract, and analysed for spend concentration and unusual growth; findings requiring action are logged with owners, and failure to complete a cycle triggers escalation to the Finance operations accountable owner.	Finance and operations accountable owner	Action log with owners; Performance and pricing review records; Re-screening results for ownership and sanctions; Risk-tiered monitoring schedule; Spend concentration analysis	100% of high-risk third parties reviewed within the defined cycle with findings actioned by due date.
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (Every qualifying transaction; monthly splitting and override review), with a management sample and any exceptions recorded.	Finance operations accountable owner	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	100% of above-threshold transactions carry an independent second approval, with all overrides reviewed monthly.
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (Before every supplier activation; annual refresh for high-risk suppliers), with a management sample and any exceptions recorded.	Finance and operations accountable owner	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	100% of newly activated suppliers have a complete, pre-activation evidence pack and independent approval.
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (Quarterly and on every joiner, mover or leaver event), with a management sample and any exceptions recorded.	Operations accountable owner	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	100% population reviewed quarterly and 95% of removal exceptions closed within 10 business days.
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (Role list reviewed annually; measures applied continuously per role), with a management sample and any exceptions recorded.	Operations accountable owner / People workforce accountable owner	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	Every identified high-risk role has at least one evidenced compensating measure operating in the period.

HORIZON	WORK TYPE	ACTION	OWNER	COMPLETION CRITERION	EFFECTIVENESS MEASURE
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (Quarterly and on every joiner, mover or leaver event), with a management sample and any exceptions recorded.	Operations accountable owner	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	100% of ordinary system and data access is reviewed on schedule and stale access is removed within the defined service level.
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (Before every payroll payment run; monthly trend review), with a management sample and any exceptions recorded.	Finance operations accountable owner / People workforce accountable owner	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	Every payroll run has a completed independent pre-payment review with all exceptions resolved or formally escalated.
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (Each cash-handling shift/day; monthly exception and trend review), with a management sample and any exceptions recorded.	Finance and operations accountable owner	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	All cash points reconcile each cycle, with every difference investigated and resolved or escalated within the defined period.
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (Movement on each event; periodic counts; monthly exception review), with a management sample and any exceptions recorded.	Finance and operations accountable owner	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	All material stock and physical assets are counted and reconciled on schedule, with shrinkage and write-offs independently reviewed.
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (Daily/weekly triage; weekly ageing escalation; monthly quality review), with a management sample and any exceptions recorded.	Finance and operations accountable owner	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	95% of alerts closed within SLA and fewer than 5% unsupported closures in monthly samples.
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (Scheduled rule execution at least monthly; monthly tuning review), with a management sample and any exceptions recorded.	Finance operations accountable owner / Technology security accountable owner	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	All priority fraud scenarios have at least one operating data check, with monthly tuning completed.
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (Continuous availability; annual training; quarterly timeliness review), with a management sample and any exceptions recorded.	Risk compliance accountable owner	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	100% of qualifying matters escalated within the stated timeframe, with an available conflict-free route.
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (At least annually, and after material detection change), with a management sample and any exceptions recorded.	Independent governing oversight	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	An independent effectiveness review is completed each period with all findings closed by due date.
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (Continuous or scheduled monitoring; monthly provider-coverage review), with a management sample and any exceptions recorded.	Operations accountable owner / Technology security accountable owner	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	All relevant external-party channels have defined monitoring or provider-report coverage, with material exceptions triaged within the agreed SLA.
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (Applied on every case; matrix reviewed annually), with a management sample and any exceptions recorded.	Operations accountable owner / Legal investigations accountable owner	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	100% of cases show a recorded decision-maker and rationale at each defined stage, with recusals applied where required.
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (At collection and every transfer; quarterly custody-log review), with a management sample and any exceptions recorded.	Legal investigations accountable owner / Operations accountable owner	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	100% of sampled material-case evidence has a complete custody trail and matching integrity check.
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (Assessed at triage on every case; provider panel reviewed annually), with a management sample and any exceptions recorded.	Legal investigations accountable owner / Finance operations accountable owner	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	Every qualifying case records a specialist engagement decision, with providers pre-qualified before use.

HORIZON	WORK TYPE	ACTION	OWNER	COMPLETION CRITERION	EFFECTIVENESS MEASURE
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (Continuous publication; annual live channel test and awareness measurement), with a management sample and any exceptions recorded.	People workforce accountable owner	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	Annual live channel test passes and at least 90% of surveyed staff can describe how to submit a report.
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (Continuous intake; monthly case-ageing review; annual channel test), with a management sample and any exceptions recorded.	Independent governing oversight / CEO	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	Relevant external stakeholders can find and use the reporting route, with reports acknowledged and triaged within the defined service level.
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (Annual declaration cycle, on-change updates, periodic data matching), with a management sample and any exceptions recorded.	Finance operations accountable owner / Legal investigations accountable owner	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	At least 98% declaration completion for in-scope roles, with every identified conflict carrying an applied management action.
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (Risk-based cycle, at minimum annually for high-risk third parties), with a management sample and any exceptions recorded.	Finance and operations accountable owner	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	100% of high-risk third parties reviewed within the defined cycle with findings actioned by due date.
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (Continuous logging; quarterly recertification; event-driven removal), with a management sample and any exceptions recorded.	Technology security accountable owner	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	100% privileged accounts recertified quarterly; leaver access removed within 24 hours; zero unjustified shared admin accounts.
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (Quarterly and after material role or system change), with a management sample and any exceptions recorded.	Technology security accountable owner	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	100% of sensitive and administrator access is reviewed each quarter, with removals completed within the defined service level.
6-12 months	Assure & review	A management or assurance review of C-22 covering effectiveness, exception trend and dependency, evidenced against: 100% of above-threshold transactions carry an independent second approval, with all overrides reviewed monthly.	Finance operations accountable owner	100% of above-threshold transactions carry an independent second approval, with all overrides reviewed monthly.	100% of above-threshold transactions carry an independent second approval, with all overrides reviewed monthly.
6-12 months	Assure & review	A management or assurance review of C-17 covering effectiveness, exception trend and dependency, evidenced against: 100% of newly activated suppliers have a complete, pre-activation evidence pack and independent approval.	Finance and operations accountable owner	100% of newly activated suppliers have a complete, pre-activation evidence pack and independent approval.	100% of newly activated suppliers have a complete, pre-activation evidence pack and independent approval.
6-12 months	Assure & review	A management or assurance review of C-07 covering effectiveness, exception trend and dependency, evidenced against: 100% population reviewed quarterly and 95% of removal exceptions closed within 10 business days.	Operations accountable owner	100% population reviewed quarterly and 95% of removal exceptions closed within 10 business days.	100% population reviewed quarterly and 95% of removal exceptions closed within 10 business days.
6-12 months	Assure & review	A management or assurance review of C-08 covering effectiveness, exception trend and dependency, evidenced against: Every identified high-risk role has at least one evidenced compensating measure operating in the period.	Operations accountable owner / People workforce accountable owner	Every identified high-risk role has at least one evidenced compensating measure operating in the period.	Every identified high-risk role has at least one evidenced compensating measure operating in the period.
6-12 months	Assure & review	A management or assurance review of C-09 covering effectiveness, exception trend and dependency, evidenced against: 100% of ordinary system and data access is reviewed on schedule and stale access is removed within the defined service level.	Operations accountable owner	100% of ordinary system and data access is reviewed on schedule and stale access is removed within the defined service level.	100% of ordinary system and data access is reviewed on schedule and stale access is removed within the defined service level.

HORIZON	WORK TYPE	ACTION	OWNER	COMPLETION CRITERION	EFFECTIVENESS MEASURE
6-12 months	Assure & review	A management or assurance review of C-23 covering effectiveness, exception trend and dependency, evidenced against: Every payroll run has a completed independent pre-payment review with all exceptions resolved or formally escalated.	Finance operations accountable owner / People workforce accountable owner	Every payroll run has a completed independent pre-payment review with all exceptions resolved or formally escalated.	Every payroll run has a completed independent pre-payment review with all exceptions resolved or formally escalated.
6-12 months	Assure & review	A management or assurance review of C-24 covering effectiveness, exception trend and dependency, evidenced against: All cash points reconcile each cycle, with every difference investigated and resolved or escalated within the defined period.	Finance and operations accountable owner	All cash points reconcile each cycle, with every difference investigated and resolved or escalated within the defined period.	All cash points reconcile each cycle, with every difference investigated and resolved or escalated within the defined period.
6-12 months	Assure & review	A management or assurance review of C-25 covering effectiveness, exception trend and dependency, evidenced against: All material stock and physical assets are counted and reconciled on schedule, with shrinkage and write-offs independently reviewed.	Finance and operations accountable owner	All material stock and physical assets are counted and reconciled on schedule, with shrinkage and write-offs independently reviewed.	All material stock and physical assets are counted and reconciled on schedule, with shrinkage and write-offs independently reviewed.
6-12 months	Assure & review	A management or assurance review of C-01 covering effectiveness, exception trend and dependency, evidenced against: 95% of alerts closed within SLA and fewer than 5% unsupported closures in monthly samples.	Finance and operations accountable owner	95% of alerts closed within SLA and fewer than 5% unsupported closures in monthly samples.	95% of alerts closed within SLA and fewer than 5% unsupported closures in monthly samples.
6-12 months	Assure & review	A management or assurance review of C-02 covering effectiveness, exception trend and dependency, evidenced against: All priority fraud scenarios have at least one operating data check, with monthly tuning completed.	Finance operations accountable owner / Technology security accountable owner	All priority fraud scenarios have at least one operating data check, with monthly tuning completed.	All priority fraud scenarios have at least one operating data check, with monthly tuning completed.
6-12 months	Assure & review	A management or assurance review of C-04 covering effectiveness, exception trend and dependency, evidenced against: 100% of qualifying matters escalated within the stated timeframe, with an available conflict-free route.	Risk compliance accountable owner	100% of qualifying matters escalated within the stated timeframe, with an available conflict-free route.	100% of qualifying matters escalated within the stated timeframe, with an available conflict-free route.
6-12 months	Assure & review	A management or assurance review of C-05 covering effectiveness, exception trend and dependency, evidenced against: An independent effectiveness review is completed each period with all findings closed by due date.	Independent governing oversight	An independent effectiveness review is completed each period with all findings closed by due date.	An independent effectiveness review is completed each period with all findings closed by due date.
6-12 months	Assure & review	A management or assurance review of C-06 covering effectiveness, exception trend and dependency, evidenced against: All relevant external-party channels have defined monitoring or provider-report coverage, with material exceptions triaged within the agreed SLA.	Operations accountable owner / Technology security accountable owner	All relevant external-party channels have defined monitoring or provider-report coverage, with material exceptions triaged within the agreed SLA.	All relevant external-party channels have defined monitoring or provider-report coverage, with material exceptions triaged within the agreed SLA.
6-12 months	Assure & review	A management or assurance review of C-12 covering effectiveness, exception trend and dependency, evidenced against: 100% of cases show a recorded decision-maker and rationale at each defined stage, with recusals applied where required.	Operations accountable owner / Legal investigations accountable owner	100% of cases show a recorded decision-maker and rationale at each defined stage, with recusals applied where required.	100% of cases show a recorded decision-maker and rationale at each defined stage, with recusals applied where required.
6-12 months	Assure & review	A management or assurance review of C-13 covering effectiveness, exception trend and dependency, evidenced against: 100% of sampled material-case evidence has a complete custody trail and matching integrity check.	Legal investigations accountable owner / Operations accountable owner	100% of sampled material-case evidence has a complete custody trail and matching integrity check.	100% of sampled material-case evidence has a complete custody trail and matching integrity check.

HORIZON	WORK TYPE	ACTION	OWNER	COMPLETION CRITERION	EFFECTIVENESS MEASURE
6-12 months	Assure & review	A management or assurance review of C-14 covering effectiveness, exception trend and dependency, evidenced against: Every qualifying case records a specialist engagement decision, with providers pre-qualified before use.	Legal investigations accountable owner / Finance operations accountable owner	Every qualifying case records a specialist engagement decision, with providers pre-qualified before use.	Every qualifying case records a specialist engagement decision, with providers pre-qualified before use.
6-12 months	Assure & review	A management or assurance review of C-15 covering effectiveness, exception trend and dependency, evidenced against: Annual live channel test passes and at least 90% of surveyed staff can describe how to submit a report.	People workforce accountable owner	Annual live channel test passes and at least 90% of surveyed staff can describe how to submit a report.	Annual live channel test passes and at least 90% of surveyed staff can describe how to submit a report.
6-12 months	Assure & review	A management or assurance review of C-16 covering effectiveness, exception trend and dependency, evidenced against: Relevant external stakeholders can find and use the reporting route, with reports acknowledged and triaged within the defined service level.	Independent governing oversight / CEO	Relevant external stakeholders can find and use the reporting route, with reports acknowledged and triaged within the defined service level.	Relevant external stakeholders can find and use the reporting route, with reports acknowledged and triaged within the defined service level.
6-12 months	Assure & review	A management or assurance review of C-18 covering effectiveness, exception trend and dependency, evidenced against: At least 98% declaration completion for in-scope roles, with every identified conflict carrying an applied management action.	Finance operations accountable owner / Legal investigations accountable owner	At least 98% declaration completion for in-scope roles, with every identified conflict carrying an applied management action.	At least 98% declaration completion for in-scope roles, with every identified conflict carrying an applied management action.
6-12 months	Assure & review	A management or assurance review of C-19 covering effectiveness, exception trend and dependency, evidenced against: 100% of high-risk third parties reviewed within the defined cycle with findings actioned by due date.	Finance and operations accountable owner	100% of high-risk third parties reviewed within the defined cycle with findings actioned by due date.	100% of high-risk third parties reviewed within the defined cycle with findings actioned by due date.
6-12 months	Assure & review	A management or assurance review of C-10 covering effectiveness, exception trend and dependency, evidenced against: 100% privileged accounts recertified quarterly; leaver access removed within 24 hours; zero unjustified shared admin accounts.	Technology security accountable owner	100% privileged accounts recertified quarterly; leaver access removed within 24 hours; zero unjustified shared admin accounts.	100% privileged accounts recertified quarterly; leaver access removed within 24 hours; zero unjustified shared admin accounts.
6-12 months	Assure & review	A management or assurance review of C-11 covering effectiveness, exception trend and dependency, evidenced against: 100% of sensitive and administrator access is reviewed each quarter, with removals completed within the defined service level.	Technology security accountable owner	100% of sensitive and administrator access is reviewed each quarter, with removals completed within the defined service level.	100% of sensitive and administrator access is reviewed each quarter, with removals completed within the defined service level.

APPENDIX F

Measurement register

The effectiveness test behind each recommended control, grouped by programme. These are the signals management should expect once the control operates.

Detection and exception review

MEASURE	CONTROLS IT COVERS
95% of alerts closed within SLA and fewer than 5% unsupported closures in monthly samples.	C-01
All priority fraud scenarios have at least one operating data check, with monthly tuning completed.	C-02
Every material process has at least one operating indicator for internal misuse and one for external threat where relevant.	C-03
100% of qualifying matters escalated within the stated timeframe, with an available conflict-free route.	C-04
An independent effectiveness review is completed each period with all findings closed by due date.	C-05
All relevant external-party channels have defined monitoring or provider-report coverage, with material exceptions triaged within the agreed SLA.	C-06

Identity and access challenge

MEASURE	CONTROLS IT COVERS
100% population reviewed quarterly and 95% of removal exceptions closed within 10 business days.	C-07
Every identified high-risk role has at least one evidenced compensating measure operating in the period.	C-08
100% of ordinary system and data access is reviewed on schedule and stale access is removed within the defined service level.	C-09
100% privileged accounts recertified quarterly; leaver access removed within 24 hours; zero unjustified shared admin accounts.	C-10
100% of sensitive and administrator access is reviewed each quarter, with removals completed within the defined service level.	C-11

Incident response and evidence integrity

MEASURE	CONTROLS IT COVERS
100% of cases show a recorded decision-maker and rationale at each defined stage, with recusals applied where required.	C-12
100% of sampled material-case evidence has a complete custody trail and matching integrity check.	C-13
Every qualifying case records a specialist engagement decision, with providers pre-qualified before use.	C-14
Annual live channel test passes and at least 90% of surveyed staff can describe how to submit a report.	C-15
Relevant external stakeholders can find and use the reporting route, with reports acknowledged and triaged within the defined service level.	C-16

Supplier and payment integrity

MEASURE	CONTROLS IT COVERS
100% of newly activated suppliers have a complete, pre-activation evidence pack and independent approval.	C-17
At least 98% declaration completion for in-scope roles, with every identified conflict carrying an applied management action.	C-18
100% of high-risk third parties reviewed within the defined cycle with findings actioned by due date.	C-19
100% of material intermediary arrangements carry fraud-control clauses, reconciliation and periodic assurance.	C-20

Fraud governance and risk identification

MEASURE	CONTROLS IT COVERS
100% of material value-bearing processes have a signed fraud map with named controls and residual gaps.	C-21
100% of above-threshold transactions carry an independent second approval, with all overrides reviewed monthly.	C-22

Payroll integrity

MEASURE	CONTROLS IT COVERS
Every payroll run has a completed independent pre-payment review with all exceptions resolved or formally escalated.	C-23

Cash custody and reconciliation

MEASURE	CONTROLS IT COVERS
All cash points reconcile each cycle, with every difference investigated and resolved or escalated within the defined period.	C-24

Stock and physical-asset integrity

MEASURE	CONTROLS IT COVERS
All material stock and physical assets are counted and reconciled on schedule, with shrinkage and write-offs independently reviewed.	C-25